MONISH.S

ITA1409 – ETHICAL HACKING

ASSIGNMENT 1

ASSIGNMENT DETAILS	INFORMATION
Student Name	MONISH.S
Course Code	ITA1409
Course Title	Ethical Hacking

TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT

Page 1 of 10 – Scenario interpretation and programme purpose

The university initially expects approximately 20 systems and 50 staff to participate. The programme includes the student portal, learning-management system, email service and campus network. The framework must also be capable of expansion to the whole university and to external assessors.

The central design decision is to treat every assessment as a controlled engagement rather than an informal technical activity. A request is accepted only after an accountable owner, an approved purpose, a defined asset boundary, a time window and a signed authorization are recorded.

Purpose and scope

The programme is intended to provide a repeatable method for assessing the security of university technology before a major upgrade. It covers governance, not only tools. The first release addresses about 20 systems and 50 staff, while the design allows later expansion. The four named service groups are the student portal, learning-management system, email service and campus network. Each service must have an accountable owner and a documented technical boundary.

Stakeholder roles

The governing sponsor provides institutional authority and resources. The system owner confirms ownership and operational constraints. The security lead coordinates the assessment. The assessor performs only approved activities. The data-protection or privacy contact reviews personal-data handling. Legal counsel advises on uncertain legal questions. IT operations monitors service health and can request a pause. These roles should be named in each engagement record.

Practical design points

- Record the decision for 'scenario interpretation and programme purpose' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

ID	Requirement / control objective	Acceptance evidence
REQ-01	Written authority exists before testing	Signed authorization record
REQ-02	Every target has an owner and identifier	Approved asset register
REQ-03	Methods and time windows are bounded	Rules-of-engagement document
REQ-04	Personal data is minimised and protected	Privacy review and data plan
REQ-05	Findings are tracked to closure	Finding and remediation register

TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT

Page 2 of 10 – Stakeholders and accountability structure

The university initially expects approximately 20 systems and 50 staff to participate. The programme includes the student portal, learning-management system, email service and campus network. The framework must also be capable of expansion to the whole university and to external assessors.

The central design decision is to treat every assessment as a controlled engagement rather than an informal technical activity. A request is accepted only after an accountable owner, an approved purpose, a defined asset boundary, a time window and a signed authorization are recorded.

Stakeholder roles

The governing sponsor provides institutional authority and resources. The system owner confirms ownership and operational constraints. The security lead coordinates the assessment. The assessor performs only approved activities. The data-protection or privacy contact reviews personal-data handling. Legal counsel advises on uncertain legal questions. IT operations monitors service health and can request a pause. These roles should be named in each engagement record.

Requirements register

Core requirements include written authorization, a precise scope, an approved time window, permitted methods, prohibited actions, data-handling rules, emergency contacts, evidence retention, reporting deadlines and closure approval. Requirements are assigned a unique ID so that they can be traced to a control and a test. A requirement is not complete merely because it appears in a policy; evidence must show that the control was applied.

Practical design points

- Record the decision for 'stakeholders and accountability structure' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

ID	Requirement / control objective	Acceptance evidence
REQ-01	Written authority exists before testing	Signed authorization record
REQ-02	Every target has an owner and identifier	Approved asset register
REQ-03	Methods and time windows are bounded	Rules-of-engagement document
REQ-04	Personal data is minimised and protected	Privacy review and data plan
REQ-05	Findings are tracked to closure	Finding and remediation register

Process view

Request → Requirements → Governance controls → Assessment → Evidence → Review

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT

Page 3 of 10 – System inventory and boundary definition

The university initially expects approximately 20 systems and 50 staff to participate. The programme includes the student portal, learning-management system, email service and campus network. The framework must also be capable of expansion to the whole university and to external assessors.

The central design decision is to treat every assessment as a controlled engagement rather than an informal technical activity. A request is accepted only after an accountable owner, an approved purpose, a defined asset boundary, a time window and a signed authorization are recorded.

Requirements register

Core requirements include written authorization, a precise scope, an approved time window, permitted methods, prohibited actions, data-handling rules, emergency contacts, evidence retention, reporting deadlines and closure approval. Requirements are assigned a unique ID so that they can be traced to a control and a test. A requirement is not complete merely because it appears in a policy; evidence must show that the control was applied.

Acceptance approach

The blueprint is accepted only when every engagement has a recorded owner, valid authorization, scope, RoE, legal and privacy review where needed, a safe test environment, a finding-report route and a closure record. A sample walkthrough is used to verify that these elements work together.

Practical design points

- Record the decision for 'system inventory and boundary definition' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

ID	Requirement / control objective	Acceptance evidence
REQ-01	Written authority exists before testing	Signed authorization record
REQ-02	Every target has an owner and identifier	Approved asset register
REQ-03	Methods and time windows are bounded	Rules-of-engagement document
REQ-04	Personal data is minimised and protected	Privacy review and data plan
REQ-05	Findings are tracked to closure	Finding and remediation register

Process view

Request → Requirements → Governance controls → Assessment → Evidence → Review

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT

Page 4 of 10 – Governance requirements register

The university initially expects approximately 20 systems and 50 staff to participate. The programme includes the student portal, learning-management system, email service and campus network. The framework must also be capable of expansion to the whole university and to external assessors.

The central design decision is to treat every assessment as a controlled engagement rather than an informal technical activity. A request is accepted only after an accountable owner, an approved purpose, a defined asset boundary, a time window and a signed authorization are recorded.

Acceptance approach

The blueprint is accepted only when every engagement has a recorded owner, valid authorization, scope, RoE, legal and privacy review where needed, a safe test environment, a finding-report route and a closure record. A sample walkthrough is used to verify that these elements work together.

Purpose and scope

The programme is intended to provide a repeatable method for assessing the security of university technology before a major upgrade. It covers governance, not only tools. The first release addresses about 20 systems and 50 staff, while the design allows later expansion. The four named service groups are the student portal, learning-management system, email service and campus network. Each service must have an accountable owner and a documented technical boundary.

Practical design points

- Record the decision for 'governance requirements register' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

ID	Requirement / control objective	Acceptance evidence
REQ-01	Written authority exists before testing	Signed authorization record
REQ-02	Every target has an owner and identifier	Approved asset register
REQ-03	Methods and time windows are bounded	Rules-of-engagement document
REQ-04	Personal data is minimised and protected	Privacy review and data plan
REQ-05	Findings are tracked to closure	Finding and remediation register

Process view

Request → Requirements → Governance controls → Assessment → Evidence → Review

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT

Page 5 of 10 – Enquiry questions and decision points

The university initially expects approximately 20 systems and 50 staff to participate. The programme includes the student portal, learning-management system, email service and campus network. The framework must also be capable of expansion to the whole university and to external assessors.

The central design decision is to treat every assessment as a controlled engagement rather than an informal technical activity. A request is accepted only after an accountable owner, an approved purpose, a defined asset boundary, a time window and a signed authorization are recorded.

Purpose and scope

The programme is intended to provide a repeatable method for assessing the security of university technology before a major upgrade. It covers governance, not only tools. The first release addresses about 20 systems and 50 staff, while the design allows later expansion. The four named service groups are the student portal, learning-management system, email service and campus network. Each service must have an accountable owner and a documented technical boundary.

Stakeholder roles

The governing sponsor provides institutional authority and resources. The system owner confirms ownership and operational constraints. The security lead coordinates the assessment. The assessor performs only approved activities. The data-protection or privacy contact reviews personal-data handling. Legal counsel advises on uncertain legal questions. IT operations monitors service health and can request a pause. These roles should be named in each engagement record.

Practical design points

- Record the decision for 'enquiry questions and decision points' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

ID	Requirement / control objective	Acceptance evidence
REQ-01	Written authority exists before testing	Signed authorization record
REQ-02	Every target has an owner and identifier	Approved asset register
REQ-03	Methods and time windows are bounded	Rules-of-engagement document
REQ-04	Personal data is minimised and protected	Privacy review and data plan
REQ-05	Findings are tracked to closure	Finding and remediation register

Process view

Request → Requirements → Governance controls → Assessment → Evidence → Review

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT

Page 6 of 10 – Framework architecture and component interaction

The university initially expects approximately 20 systems and 50 staff to participate. The programme includes the student portal, learning-management system, email service and campus network. The framework must also be capable of expansion to the whole university and to external assessors.

The central design decision is to treat every assessment as a controlled engagement rather than an informal technical activity. A request is accepted only after an accountable owner, an approved purpose, a defined asset boundary, a time window and a signed authorization are recorded.

Stakeholder roles

The governing sponsor provides institutional authority and resources. The system owner confirms ownership and operational constraints. The security lead coordinates the assessment. The assessor performs only approved activities. The data-protection or privacy contact reviews personal-data handling. Legal counsel advises on uncertain legal questions. IT operations monitors service health and can request a pause. These roles should be named in each engagement record.

Requirements register

Core requirements include written authorization, a precise scope, an approved time window, permitted methods, prohibited actions, data-handling rules, emergency contacts, evidence retention, reporting deadlines and closure approval. Requirements are assigned a unique ID so that they can be traced to a control and a test. A requirement is not complete merely because it appears in a policy; evidence must show that the control was applied.

Practical design points

- Record the decision for 'framework architecture and component interaction' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

ID	Requirement / control objective	Acceptance evidence
REQ-01	Written authority exists before testing	Signed authorization record
REQ-02	Every target has an owner and identifier	Approved asset register
REQ-03	Methods and time windows are bounded	Rules-of-engagement document
REQ-04	Personal data is minimised and protected	Privacy review and data plan
REQ-05	Findings are tracked to closure	Finding and remediation register

Process view

Request → Requirements → Governance controls → Assessment → Evidence → Review

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT

Page 7 of 10 – Design criteria and acceptance measures

The university initially expects approximately 20 systems and 50 staff to participate. The programme includes the student portal, learning-management system, email service and campus network. The framework must also be capable of expansion to the whole university and to external assessors.

The central design decision is to treat every assessment as a controlled engagement rather than an informal technical activity. A request is accepted only after an accountable owner, an approved purpose, a defined asset boundary, a time window and a signed authorization are recorded.

Requirements register

Core requirements include written authorization, a precise scope, an approved time window, permitted methods, prohibited actions, data-handling rules, emergency contacts, evidence retention, reporting deadlines and closure approval. Requirements are assigned a unique ID so that they can be traced to a control and a test. A requirement is not complete merely because it appears in a policy; evidence must show that the control was applied.

Acceptance approach

The blueprint is accepted only when every engagement has a recorded owner, valid authorization, scope, RoE, legal and privacy review where needed, a safe test environment, a finding-report route and a closure record. A sample walkthrough is used to verify that these elements work together.

Practical design points

- Record the decision for 'design criteria and acceptance measures' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

ID	Requirement / control objective	Acceptance evidence
REQ-01	Written authority exists before testing	Signed authorization record
REQ-02	Every target has an owner and identifier	Approved asset register
REQ-03	Methods and time windows are bounded	Rules-of-engagement document
REQ-04	Personal data is minimised and protected	Privacy review and data plan
REQ-05	Findings are tracked to closure	Finding and remediation register

Process view

Request → Requirements → Governance controls → Assessment → Evidence → Review

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT

Page 8 of 10 – Risk assumptions and constraints

The university initially expects approximately 20 systems and 50 staff to participate. The programme includes the student portal, learning-management system, email service and campus network. The framework must also be capable of expansion to the whole university and to external assessors.

The central design decision is to treat every assessment as a controlled engagement rather than an informal technical activity. A request is accepted only after an accountable owner, an approved purpose, a defined asset boundary, a time window and a signed authorization are recorded.

Acceptance approach

The blueprint is accepted only when every engagement has a recorded owner, valid authorization, scope, RoE, legal and privacy review where needed, a safe test environment, a finding-report route and a closure record. A sample walkthrough is used to verify that these elements work together.

Purpose and scope

The programme is intended to provide a repeatable method for assessing the security of university technology before a major upgrade. It covers governance, not only tools. The first release addresses about 20 systems and 50 staff, while the design allows later expansion. The four named service groups are the student portal, learning-management system, email service and campus network. Each service must have an accountable owner and a documented technical boundary.

Practical design points

- Record the decision for 'risk assumptions and constraints' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

ID	Requirement / control objective	Acceptance evidence
REQ-01	Written authority exists before testing	Signed authorization record
REQ-02	Every target has an owner and identifier	Approved asset register
REQ-03	Methods and time windows are bounded	Rules-of-engagement document
REQ-04	Personal data is minimised and protected	Privacy review and data plan
REQ-05	Findings are tracked to closure	Finding and remediation register

Process view

Request → Requirements → Governance controls → Assessment → Evidence → Review

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT

Page 9 of 10 – Requirements-to-control traceability

The university initially expects approximately 20 systems and 50 staff to participate. The programme includes the student portal, learning-management system, email service and campus network. The framework must also be capable of expansion to the whole university and to external assessors.

The central design decision is to treat every assessment as a controlled engagement rather than an informal technical activity. A request is accepted only after an accountable owner, an approved purpose, a defined asset boundary, a time window and a signed authorization are recorded.

Purpose and scope

The programme is intended to provide a repeatable method for assessing the security of university technology before a major upgrade. It covers governance, not only tools. The first release addresses about 20 systems and 50 staff, while the design allows later expansion. The four named service groups are the student portal, learning-management system, email service and campus network. Each service must have an accountable owner and a documented technical boundary.

Stakeholder roles

The governing sponsor provides institutional authority and resources. The system owner confirms ownership and operational constraints. The security lead coordinates the assessment. The assessor performs only approved activities. The data-protection or privacy contact reviews personal-data handling. Legal counsel advises on uncertain legal questions. IT operations monitors service health and can request a pause. These roles should be named in each engagement record.

Practical design points

- Record the decision for 'requirements-to-control traceability' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

ID	Requirement / control objective	Acceptance evidence
REQ-01	Written authority exists before testing	Signed authorization record
REQ-02	Every target has an owner and identifier	Approved asset register
REQ-03	Methods and time windows are bounded	Rules-of-engagement document
REQ-04	Personal data is minimised and protected	Privacy review and data plan
REQ-05	Findings are tracked to closure	Finding and remediation register

Process view

Request → Requirements → Governance controls → Assessment → Evidence → Review

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT

Page 10 of 10 – Task 1 conclusion and blueprint validation

The university initially expects approximately 20 systems and 50 staff to participate. The programme includes the student portal, learning-management system, email service and campus network. The framework must also be capable of expansion to the whole university and to external assessors.

The central design decision is to treat every assessment as a controlled engagement rather than an informal technical activity. A request is accepted only after an accountable owner, an approved purpose, a defined asset boundary, a time window and a signed authorization are recorded.

Stakeholder roles

The governing sponsor provides institutional authority and resources. The system owner confirms ownership and operational constraints. The security lead coordinates the assessment. The assessor performs only approved activities. The data-protection or privacy contact reviews personal-data handling. Legal counsel advises on uncertain legal questions. IT operations monitors service health and can request a pause. These roles should be named in each engagement record.

Requirements register

Core requirements include written authorization, a precise scope, an approved time window, permitted methods, prohibited actions, data-handling rules, emergency contacts, evidence retention, reporting deadlines and closure approval. Requirements are assigned a unique ID so that they can be traced to a control and a test. A requirement is not complete merely because it appears in a policy; evidence must show that the control was applied.

Practical design points

- Record the decision for 'task 1 conclusion and blueprint validation' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

ID	Requirement / control objective	Acceptance evidence
REQ-01	Written authority exists before testing	Signed authorization record
REQ-02	Every target has an owner and identifier	Approved asset register
REQ-03	Methods and time windows are bounded	Rules-of-engagement document
REQ-04	Personal data is minimised and protected	Privacy review and data plan
REQ-05	Findings are tracked to closure	Finding and remediation register

Process view

Request → Requirements → Governance controls → Assessment → Evidence → Review

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 2 – DESIGN A HACKER THREAT MODEL AND CLASSIFICATION

Page 1 of 10 – Purpose and scope of the threat model

The university threat model considers people and groups that may attempt to access, disrupt, manipulate or expose university information. Relevant assets include student records, staff accounts, learning materials, email, research systems and network services.

Classification is based on observable behaviour, authorization, intent, capability and target selection. Labels are used to support risk decisions, not to make unsupported claims about a person's identity. An actor may move between categories when evidence or behaviour changes.

Actor attributes

Classification uses five questions: does the actor have permission; what is the apparent motivation; what capability is demonstrated; what target is selected; and what action was actually observed? These attributes prevent a label from being assigned only because an individual uses a particular tool. Evidence may include the source of a request, access logs, messages, observed techniques and the actor's response to boundaries.

White-hat and black-hat

A white-hat tester operates with explicit permission, follows the agreed scope and reports findings through the approved channel. A black-hat actor intentionally acts without permission for harmful, deceptive or personal gain. The same technical technique may appear in both cases; authorization, intent and conduct determine the ethical classification.

Practical design points

- Record the decision for 'purpose and scope of the threat model' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Actor category	Typical motivation / capability	Possible university target
White-hat	Authorized assurance; professional testing skills	Approved portal or staging system
Black-hat	Financial gain, theft or disruption; variable capability	Accounts, email, student records
Grey-hat	Curiosity or recognition; variable capability	Public-facing portal
Insider	Convenience, grievance or misuse of access	Department shares and admin accounts
Hacktivist	Political or social message; publicity-seeking	Public website and email service

Process view

Observed behaviour → Authorization check → Motivation / capability → Actor category → Risk response

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 2 – DESIGN A HACKER THREAT MODEL AND CLASSIFICATION

Page 2 of 10 – Consistent actor-classification criteria

The university threat model considers people and groups that may attempt to access, disrupt, manipulate or expose university information. Relevant assets include student records, staff accounts, learning materials, email, research systems and network services.

Classification is based on observable behaviour, authorization, intent, capability and target selection. Labels are used to support risk decisions, not to make unsupported claims about a person's identity. An actor may move between categories when evidence or behaviour changes.

White-hat and black-hat

A white-hat tester operates with explicit permission, follows the agreed scope and reports findings through the approved channel. A black-hat actor intentionally acts without permission for harmful, deceptive or personal gain. The same technical technique may appear in both cases; authorization, intent and conduct determine the ethical classification.

Grey-hat and script kiddie

A grey-hat actor may identify a weakness without prior permission and may disclose it with mixed or unclear intent. Good intentions do not remove the unauthorized nature of the initial access. A script kiddie relies heavily on readily available scripts or tools and may have limited understanding of their effects. Limited skill does not make the activity harmless.

Practical design points

- Record the decision for 'consistent actor-classification criteria' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Actor category	Typical motivation / capability	Possible university target
White-hat	Authorized assurance; professional testing skills	Approved portal or staging system
Black-hat	Financial gain, theft or disruption; variable capability	Accounts, email, student records
Grey-hat	Curiosity or recognition; variable capability	Public-facing portal
Insider	Convenience, grievance or misuse of access	Department shares and admin accounts
Hacktivist	Political or social message; publicity-seeking	Public website and email service

Process view

Observed behaviour → Authorization check → Motivation / capability → Actor category → Risk response

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 2 – DESIGN A HACKER THREAT MODEL AND CLASSIFICATION

Page 3 of 10 – White-hat and black-hat actors

The university threat model considers people and groups that may attempt to access, disrupt, manipulate or expose university information. Relevant assets include student records, staff accounts, learning materials, email, research systems and network services.

Classification is based on observable behaviour, authorization, intent, capability and target selection. Labels are used to support risk decisions, not to make unsupported claims about a person's identity. An actor may move between categories when evidence or behaviour changes.

Grey-hat and script kiddie

A grey-hat actor may identify a weakness without prior permission and may disclose it with mixed or unclear intent. Good intentions do not remove the unauthorized nature of the initial access. A script kiddie relies heavily on readily available scripts or tools and may have limited understanding of their effects. Limited skill does not make the activity harmless.

Other actors

A hacktivist may target university systems to promote a cause. An insider may misuse legitimate access or make a careless mistake. A state-sponsored actor may have significant resources and long-term objectives. These are behavioural threat categories; the university should avoid attributing an incident to a state or group without reliable evidence.

Practical design points

- Record the decision for 'white-hat and black-hat actors' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Actor category	Typical motivation / capability	Possible university target
White-hat	Authorized assurance; professional testing skills	Approved portal or staging system
Black-hat	Financial gain, theft or disruption; variable capability	Accounts, email, student records
Grey-hat	Curiosity or recognition; variable capability	Public-facing portal
Insider	Convenience, grievance or misuse of access	Department shares and admin accounts
Hacktivist	Political or social message; publicity-seeking	Public website and email service

Process view

Observed behaviour → Authorization check → Motivation / capability → Actor category → Risk response

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 2 – DESIGN A HACKER THREAT MODEL AND CLASSIFICATION

Page 4 of 10 – Grey-hat and script-kiddie actors

The university threat model considers people and groups that may attempt to access, disrupt, manipulate or expose university information. Relevant assets include student records, staff accounts, learning materials, email, research systems and network services.

Classification is based on observable behaviour, authorization, intent, capability and target selection. Labels are used to support risk decisions, not to make unsupported claims about a person's identity. An actor may move between categories when evidence or behaviour changes.

Other actors

A hacktivist may target university systems to promote a cause. An insider may misuse legitimate access or make a careless mistake. A state-sponsored actor may have significant resources and long-term objectives. These are behavioural threat categories; the university should avoid attributing an incident to a state or group without reliable evidence.

Actor attributes

Classification uses five questions: does the actor have permission; what is the apparent motivation; what capability is demonstrated; what target is selected; and what action was actually observed? These attributes prevent a label from being assigned only because an individual uses a particular tool. Evidence may include the source of a request, access logs, messages, observed techniques and the actor's response to boundaries.

Practical design points

- Record the decision for 'grey-hat and script-kiddie actors' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Actor category	Typical motivation / capability	Possible university target
White-hat	Authorized assurance; professional testing skills	Approved portal or staging system
Black-hat	Financial gain, theft or disruption; variable capability	Accounts, email, student records
Grey-hat	Curiosity or recognition; variable capability	Public-facing portal
Insider	Convenience, grievance or misuse of access	Department shares and admin accounts
Hacktivist	Political or social message; publicity-seeking	Public website and email service

Process view

Observed behaviour → Authorization check → Motivation / capability → Actor category → Risk response

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 2 – DESIGN A HACKER THREAT MODEL AND CLASSIFICATION

Page 5 of 10 – Hacktivist and insider threats

The university threat model considers people and groups that may attempt to access, disrupt, manipulate or expose university information. Relevant assets include student records, staff accounts, learning materials, email, research systems and network services.

Classification is based on observable behaviour, authorization, intent, capability and target selection. Labels are used to support risk decisions, not to make unsupported claims about a person's identity. An actor may move between categories when evidence or behaviour changes.

Actor attributes

Classification uses five questions: does the actor have permission; what is the apparent motivation; what capability is demonstrated; what target is selected; and what action was actually observed? These attributes prevent a label from being assigned only because an individual uses a particular tool. Evidence may include the source of a request, access logs, messages, observed techniques and the actor's response to boundaries.

White-hat and black-hat

A white-hat tester operates with explicit permission, follows the agreed scope and reports findings through the approved channel. A black-hat actor intentionally acts without permission for harmful, deceptive or personal gain. The same technical technique may appear in both cases; authorization, intent and conduct determine the ethical classification.

Practical design points

- Record the decision for 'hacktivist and insider threats' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Actor category	Typical motivation / capability	Possible university target
White-hat	Authorized assurance; professional testing skills	Approved portal or staging system
Black-hat	Financial gain, theft or disruption; variable capability	Accounts, email, student records
Grey-hat	Curiosity or recognition; variable capability	Public-facing portal
Insider	Convenience, grievance or misuse of access	Department shares and admin accounts
Hacktivist	Political or social message; publicity-seeking	Public website and email service

Process view

Observed behaviour → Authorization check → Motivation / capability → Actor category → Risk response

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 2 – DESIGN A HACKER THREAT MODEL AND CLASSIFICATION

Page 6 of 10 – State-sponsored and organised actors

The university threat model considers people and groups that may attempt to access, disrupt, manipulate or expose university information. Relevant assets include student records, staff accounts, learning materials, email, research systems and network services.

Classification is based on observable behaviour, authorization, intent, capability and target selection. Labels are used to support risk decisions, not to make unsupported claims about a person's identity. An actor may move between categories when evidence or behaviour changes.

White-hat and black-hat

A white-hat tester operates with explicit permission, follows the agreed scope and reports findings through the approved channel. A black-hat actor intentionally acts without permission for harmful, deceptive or personal gain. The same technical technique may appear in both cases; authorization, intent and conduct determine the ethical classification.

Grey-hat and script kiddie

A grey-hat actor may identify a weakness without prior permission and may disclose it with mixed or unclear intent. Good intentions do not remove the unauthorized nature of the initial access. A script kiddie relies heavily on readily available scripts or tools and may have limited understanding of their effects. Limited skill does not make the activity harmless.

Practical design points

- Record the decision for 'state-sponsored and organised actors' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Actor category	Typical motivation / capability	Possible university target
White-hat	Authorized assurance; professional testing skills	Approved portal or staging system
Black-hat	Financial gain, theft or disruption; variable capability	Accounts, email, student records
Grey-hat	Curiosity or recognition; variable capability	Public-facing portal
Insider	Convenience, grievance or misuse of access	Department shares and admin accounts
Hacktivist	Political or social message; publicity-seeking	Public website and email service

Process view

Observed behaviour → Authorization check → Motivation / capability → Actor category → Risk response

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 2 – DESIGN A HACKER THREAT MODEL AND CLASSIFICATION

Page 7 of 10 – University asset and motivation mapping

The university threat model considers people and groups that may attempt to access, disrupt, manipulate or expose university information. Relevant assets include student records, staff accounts, learning materials, email, research systems and network services.

Classification is based on observable behaviour, authorization, intent, capability and target selection. Labels are used to support risk decisions, not to make unsupported claims about a person's identity. An actor may move between categories when evidence or behaviour changes.

Grey-hat and script kiddie

A grey-hat actor may identify a weakness without prior permission and may disclose it with mixed or unclear intent. Good intentions do not remove the unauthorized nature of the initial access. A script kiddie relies heavily on readily available scripts or tools and may have limited understanding of their effects. Limited skill does not make the activity harmless.

Other actors

A hacktivist may target university systems to promote a cause. An insider may misuse legitimate access or make a careless mistake. A state-sponsored actor may have significant resources and long-term objectives. These are behavioural threat categories; the university should avoid attributing an incident to a state or group without reliable evidence.

Practical design points

- Record the decision for 'university asset and motivation mapping' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Actor category	Typical motivation / capability	Possible university target
White-hat	Authorized assurance; professional testing skills	Approved portal or staging system
Black-hat	Financial gain, theft or disruption; variable capability	Accounts, email, student records
Grey-hat	Curiosity or recognition; variable capability	Public-facing portal
Insider	Convenience, grievance or misuse of access	Department shares and admin accounts
Hacktivist	Political or social message; publicity-seeking	Public website and email service

Process view

Observed behaviour → Authorization check → Motivation / capability → Actor category → Risk response

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 2 – DESIGN A HACKER THREAT MODEL AND CLASSIFICATION

Page 8 of 10 – Borderline actor classification exercise

The university threat model considers people and groups that may attempt to access, disrupt, manipulate or expose university information. Relevant assets include student records, staff accounts, learning materials, email, research systems and network services.

Classification is based on observable behaviour, authorization, intent, capability and target selection. Labels are used to support risk decisions, not to make unsupported claims about a person's identity. An actor may move between categories when evidence or behaviour changes.

Other actors

A hacktivist may target university systems to promote a cause. An insider may misuse legitimate access or make a careless mistake. A state-sponsored actor may have significant resources and long-term objectives. These are behavioural threat categories; the university should avoid attributing an incident to a state or group without reliable evidence.

Actor attributes

Classification uses five questions: does the actor have permission; what is the apparent motivation; what capability is demonstrated; what target is selected; and what action was actually observed? These attributes prevent a label from being assigned only because an individual uses a particular tool. Evidence may include the source of a request, access logs, messages, observed techniques and the actor's response to boundaries.

Practical design points

- Record the decision for 'borderline actor classification exercise' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Actor category	Typical motivation / capability	Possible university target
White-hat	Authorized assurance; professional testing skills	Approved portal or staging system
Black-hat	Financial gain, theft or disruption; variable capability	Accounts, email, student records
Grey-hat	Curiosity or recognition; variable capability	Public-facing portal
Insider	Convenience, grievance or misuse of access	Department shares and admin accounts
Hacktivist	Political or social message; publicity-seeking	Public website and email service

Process view

Observed behaviour → Authorization check → Motivation / capability → Actor category → Risk response

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 2 – DESIGN A HACKER THREAT MODEL AND CLASSIFICATION

Page 9 of 10 – Threat prioritisation and response mapping

The university threat model considers people and groups that may attempt to access, disrupt, manipulate or expose university information. Relevant assets include student records, staff accounts, learning materials, email, research systems and network services.

Classification is based on observable behaviour, authorization, intent, capability and target selection. Labels are used to support risk decisions, not to make unsupported claims about a person's identity. An actor may move between categories when evidence or behaviour changes.

Actor attributes

Classification uses five questions: does the actor have permission; what is the apparent motivation; what capability is demonstrated; what target is selected; and what action was actually observed? These attributes prevent a label from being assigned only because an individual uses a particular tool. Evidence may include the source of a request, access logs, messages, observed techniques and the actor's response to boundaries.

White-hat and black-hat

A white-hat tester operates with explicit permission, follows the agreed scope and reports findings through the approved channel. A black-hat actor intentionally acts without permission for harmful, deceptive or personal gain. The same technical technique may appear in both cases; authorization, intent and conduct determine the ethical classification.

Practical design points

- Record the decision for 'threat prioritisation and response mapping' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Actor category	Typical motivation / capability	Possible university target
White-hat	Authorized assurance; professional testing skills	Approved portal or staging system
Black-hat	Financial gain, theft or disruption; variable capability	Accounts, email, student records
Grey-hat	Curiosity or recognition; variable capability	Public-facing portal
Insider	Convenience, grievance or misuse of access	Department shares and admin accounts
Hacktivist	Political or social message; publicity-seeking	Public website and email service

Process view

Observed behaviour → Authorization check → Motivation / capability → Actor category → Risk response

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 2 – DESIGN A HACKER THREAT MODEL AND CLASSIFICATION

Page 10 of 10 – Threat model validation and conclusion

The university threat model considers people and groups that may attempt to access, disrupt, manipulate or expose university information. Relevant assets include student records, staff accounts, learning materials, email, research systems and network services.

Classification is based on observable behaviour, authorization, intent, capability and target selection. Labels are used to support risk decisions, not to make unsupported claims about a person's identity. An actor may move between categories when evidence or behaviour changes.

White-hat and black-hat

A white-hat tester operates with explicit permission, follows the agreed scope and reports findings through the approved channel. A black-hat actor intentionally acts without permission for harmful, deceptive or personal gain. The same technical technique may appear in both cases; authorization, intent and conduct determine the ethical classification.

Grey-hat and script kiddie

A grey-hat actor may identify a weakness without prior permission and may disclose it with mixed or unclear intent. Good intentions do not remove the unauthorized nature of the initial access. A script kiddie relies heavily on readily available scripts or tools and may have limited understanding of their effects. Limited skill does not make the activity harmless.

Practical design points

- Record the decision for 'threat model validation and conclusion' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Actor category	Typical motivation / capability	Possible university target
White-hat	Authorized assurance; professional testing skills	Approved portal or staging system
Black-hat	Financial gain, theft or disruption; variable capability	Accounts, email, student records
Grey-hat	Curiosity or recognition; variable capability	Public-facing portal
Insider	Convenience, grievance or misuse of access	Department shares and admin accounts
Hacktivist	Political or social message; publicity-seeking	Public website and email service

Process view

Observed behaviour → Authorization check → Motivation / capability → Actor category → Risk response

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 3 – CREATE AN ETHICS AND CODE-OF-CONDUCT MODULE

Page 1 of 10 – Ethical purpose and professional responsibilities

The code of conduct applies to internal assessors, students assisting under supervision and external security professionals. Technical skill does not provide permission by itself. The engagement letter and rules of engagement define the limits within which testing is permitted.

The ethical standard is stricter than a minimum technical permission. Testers must minimise access to personal information, avoid unnecessary service impact, preserve evidence, report honestly and stop when the activity moves outside the approved boundary.

Written permission

Before any test, the assessor must have a signed authorization from a person with delegated authority. The authorization names the engagement, assets, dates, testing team and approved methods. If the target is owned by a supplier or cloud provider, the relevant contractual permission must also be checked. An email from a technical contact is not enough unless the university's approval process recognises that person as an authorized signatory.

Confidentiality

Assessors may encounter names, contact details, grades, identity information, research data or credentials. They should avoid collecting real records when a synthetic account or test dataset is sufficient. If sensitive content is unexpectedly exposed, the assessor must stop further access, record only the minimum evidence needed and contact the designated privacy or security lead.

Practical design points

- Record the decision for 'ethical purpose and professional responsibilities' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Principle	Required behaviour	Control / evidence
Authorization	Test only after written approval	Signed authorization ID
Confidentiality	Minimise access and protect evidence	Restricted evidence folder
Integrity	Report facts accurately	Time-stamped logs
Avoid harm	Use low-impact methods and stop on instability	Stop-work log
Accountability	Identify who performed each action	Assessor activity record

Process view

Authorization → Ethical checks → Controlled testing → Evidence review → Honest report

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 3 – CREATE AN ETHICS AND CODE-OF-CONDUCT MODULE

Page 2 of 10 – Written authorization and scope discipline

The code of conduct applies to internal assessors, students assisting under supervision and external security professionals. Technical skill does not provide permission by itself. The engagement letter and rules of engagement define the limits within which testing is permitted.

The ethical standard is stricter than a minimum technical permission. Testers must minimise access to personal information, avoid unnecessary service impact, preserve evidence, report honestly and stop when the activity moves outside the approved boundary.

Confidentiality

Assessors may encounter names, contact details, grades, identity information, research data or credentials. They should avoid collecting real records when a synthetic account or test dataset is sufficient. If sensitive content is unexpectedly exposed, the assessor must stop further access, record only the minimum evidence needed and contact the designated privacy or security lead.

Integrity and honesty

Evidence must be accurate, time-stamped and linked to the engagement ID. Screenshots and logs should not be altered to make a finding appear more severe. Reports distinguish confirmed facts from assumptions and recommendations. A tester must disclose failed tests, tool errors and limitations rather than presenting incomplete work as a complete assessment.

Practical design points

- Record the decision for 'written authorization and scope discipline' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Principle	Required behaviour	Control / evidence
Authorization	Test only after written approval	Signed authorization ID
Confidentiality	Minimise access and protect evidence	Restricted evidence folder
Integrity	Report facts accurately	Time-stamped logs
Avoid harm	Use low-impact methods and stop on instability	Stop-work log
Accountability	Identify who performed each action	Assessor activity record

Process view

Authorization → Ethical checks → Controlled testing → Evidence review → Honest report

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 3 – CREATE AN ETHICS AND CODE-OF-CONDUCT MODULE

Page 3 of 10 – Confidentiality and privacy safeguards

The code of conduct applies to internal assessors, students assisting under supervision and external security professionals. Technical skill does not provide permission by itself. The engagement letter and rules of engagement define the limits within which testing is permitted.

The ethical standard is stricter than a minimum technical permission. Testers must minimise access to personal information, avoid unnecessary service impact, preserve evidence, report honestly and stop when the activity moves outside the approved boundary.

Integrity and honesty

Evidence must be accurate, time-stamped and linked to the engagement ID. Screenshots and logs should not be altered to make a finding appear more severe. Reports distinguish confirmed facts from assumptions and recommendations. A tester must disclose failed tests, tool errors and limitations rather than presenting incomplete work as a complete assessment.

Avoiding harm

Availability is a university requirement because students and staff depend on online services. Destructive payloads, uncontrolled denial-of-service activity, persistence, malware deployment and unapproved social engineering are prohibited. A tester stops immediately if instability, unexpected data exposure or a scope mismatch is observed.

Practical design points

- Record the decision for 'confidentiality and privacy safeguards' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Principle	Required behaviour	Control / evidence
Authorization	Test only after written approval	Signed authorization ID
Confidentiality	Minimise access and protect evidence	Restricted evidence folder
Integrity	Report facts accurately	Time-stamped logs
Avoid harm	Use low-impact methods and stop on instability	Stop-work log
Accountability	Identify who performed each action	Assessor activity record

Process view

Authorization → Ethical checks → Controlled testing → Evidence review → Honest report

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 3 – CREATE AN ETHICS AND CODE-OF-CONDUCT MODULE

Page 4 of 10 – Integrity, evidence handling and honesty

The code of conduct applies to internal assessors, students assisting under supervision and external security professionals. Technical skill does not provide permission by itself. The engagement letter and rules of engagement define the limits within which testing is permitted.

The ethical standard is stricter than a minimum technical permission. Testers must minimise access to personal information, avoid unnecessary service impact, preserve evidence, report honestly and stop when the activity moves outside the approved boundary.

Avoiding harm

Availability is a university requirement because students and staff depend on online services. Destructive payloads, uncontrolled denial-of-service activity, persistence, malware deployment and unapproved social engineering are prohibited. A tester stops immediately if instability, unexpected data exposure or a scope mismatch is observed.

Written permission

Before any test, the assessor must have a signed authorization from a person with delegated authority. The authorization names the engagement, assets, dates, testing team and approved methods. If the target is owned by a supplier or cloud provider, the relevant contractual permission must also be checked. An email from a technical contact is not enough unless the university's approval process recognises that person as an authorized signatory.

Practical design points

- Record the decision for 'integrity, evidence handling and honesty' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Principle	Required behaviour	Control / evidence
Authorization	Test only after written approval	Signed authorization ID
Confidentiality	Minimise access and protect evidence	Restricted evidence folder
Integrity	Report facts accurately	Time-stamped logs
Avoid harm	Use low-impact methods and stop on instability	Stop-work log
Accountability	Identify who performed each action	Assessor activity record

Process view

Authorization → Ethical checks → Controlled testing → Evidence review → Honest report

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 3 – CREATE AN ETHICS AND CODE-OF-CONDUCT MODULE

Page 5 of 10 – Avoiding harm and service availability

The code of conduct applies to internal assessors, students assisting under supervision and external security professionals. Technical skill does not provide permission by itself. The engagement letter and rules of engagement define the limits within which testing is permitted.

The ethical standard is stricter than a minimum technical permission. Testers must minimise access to personal information, avoid unnecessary service impact, preserve evidence, report honestly and stop when the activity moves outside the approved boundary.

Written permission

Before any test, the assessor must have a signed authorization from a person with delegated authority. The authorization names the engagement, assets, dates, testing team and approved methods. If the target is owned by a supplier or cloud provider, the relevant contractual permission must also be checked. An email from a technical contact is not enough unless the university's approval process recognises that person as an authorized signatory.

Confidentiality

Assessors may encounter names, contact details, grades, identity information, research data or credentials. They should avoid collecting real records when a synthetic account or test dataset is sufficient. If sensitive content is unexpectedly exposed, the assessor must stop further access, record only the minimum evidence needed and contact the designated privacy or security lead.

Practical design points

- Record the decision for 'avoiding harm and service availability' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Principle	Required behaviour	Control / evidence
Authorization	Test only after written approval	Signed authorization ID
Confidentiality	Minimise access and protect evidence	Restricted evidence folder
Integrity	Report facts accurately	Time-stamped logs
Avoid harm	Use low-impact methods and stop on instability	Stop-work log
Accountability	Identify who performed each action	Assessor activity record

Process view

Authorization → Ethical checks → Controlled testing → Evidence review → Honest report

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 3 – CREATE AN ETHICS AND CODE-OF-CONDUCT MODULE

Page 6 of 10 – Rules, checks and stop-work conditions

The code of conduct applies to internal assessors, students assisting under supervision and external security professionals. Technical skill does not provide permission by itself. The engagement letter and rules of engagement define the limits within which testing is permitted.

The ethical standard is stricter than a minimum technical permission. Testers must minimise access to personal information, avoid unnecessary service impact, preserve evidence, report honestly and stop when the activity moves outside the approved boundary.

Confidentiality

Assessors may encounter names, contact details, grades, identity information, research data or credentials. They should avoid collecting real records when a synthetic account or test dataset is sufficient. If sensitive content is unexpectedly exposed, the assessor must stop further access, record only the minimum evidence needed and contact the designated privacy or security lead.

Integrity and honesty

Evidence must be accurate, time-stamped and linked to the engagement ID. Screenshots and logs should not be altered to make a finding appear more severe. Reports distinguish confirmed facts from assumptions and recommendations. A tester must disclose failed tests, tool errors and limitations rather than presenting incomplete work as a complete assessment.

Practical design points

- Record the decision for 'rules, checks and stop-work conditions' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Principle	Required behaviour	Control / evidence
Authorization	Test only after written approval	Signed authorization ID
Confidentiality	Minimise access and protect evidence	Restricted evidence folder
Integrity	Report facts accurately	Time-stamped logs
Avoid harm	Use low-impact methods and stop on instability	Stop-work log
Accountability	Identify who performed each action	Assessor activity record

Process view

Authorization → Ethical checks → Controlled testing → Evidence review → Honest report

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 3 – CREATE AN ETHICS AND CODE-OF-CONDUCT MODULE

Page 7 of 10 – Acceptable conduct scenario

The code of conduct applies to internal assessors, students assisting under supervision and external security professionals. Technical skill does not provide permission by itself. The engagement letter and rules of engagement define the limits within which testing is permitted.

The ethical standard is stricter than a minimum technical permission. Testers must minimise access to personal information, avoid unnecessary service impact, preserve evidence, report honestly and stop when the activity moves outside the approved boundary.

Integrity and honesty

Evidence must be accurate, time-stamped and linked to the engagement ID. Screenshots and logs should not be altered to make a finding appear more severe. Reports distinguish confirmed facts from assumptions and recommendations. A tester must disclose failed tests, tool errors and limitations rather than presenting incomplete work as a complete assessment.

Avoiding harm

Availability is a university requirement because students and staff depend on online services. Destructive payloads, uncontrolled denial-of-service activity, persistence, malware deployment and unapproved social engineering are prohibited. A tester stops immediately if instability, unexpected data exposure or a scope mismatch is observed.

Practical design points

- Record the decision for 'acceptable conduct scenario' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Principle	Required behaviour	Control / evidence
Authorization	Test only after written approval	Signed authorization ID
Confidentiality	Minimise access and protect evidence	Restricted evidence folder
Integrity	Report facts accurately	Time-stamped logs
Avoid harm	Use low-impact methods and stop on instability	Stop-work log
Accountability	Identify who performed each action	Assessor activity record

Process view

Authorization → Ethical checks → Controlled testing → Evidence review → Honest report

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 3 – CREATE AN ETHICS AND CODE-OF-CONDUCT MODULE

Page 8 of 10 – Borderline conduct scenario

The code of conduct applies to internal assessors, students assisting under supervision and external security professionals. Technical skill does not provide permission by itself. The engagement letter and rules of engagement define the limits within which testing is permitted.

The ethical standard is stricter than a minimum technical permission. Testers must minimise access to personal information, avoid unnecessary service impact, preserve evidence, report honestly and stop when the activity moves outside the approved boundary.

Avoiding harm

Availability is a university requirement because students and staff depend on online services. Destructive payloads, uncontrolled denial-of-service activity, persistence, malware deployment and unapproved social engineering are prohibited. A tester stops immediately if instability, unexpected data exposure or a scope mismatch is observed.

Written permission

Before any test, the assessor must have a signed authorization from a person with delegated authority. The authorization names the engagement, assets, dates, testing team and approved methods. If the target is owned by a supplier or cloud provider, the relevant contractual permission must also be checked. An email from a technical contact is not enough unless the university's approval process recognises that person as an authorized signatory.

Practical design points

- Record the decision for 'borderline conduct scenario' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Principle	Required behaviour	Control / evidence
Authorization	Test only after written approval	Signed authorization ID
Confidentiality	Minimise access and protect evidence	Restricted evidence folder
Integrity	Report facts accurately	Time-stamped logs
Avoid harm	Use low-impact methods and stop on instability	Stop-work log
Accountability	Identify who performed each action	Assessor activity record

Process view

Authorization → Ethical checks → Controlled testing → Evidence review → Honest report

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 3 – CREATE AN ETHICS AND CODE-OF-CONDUCT MODULE

Page 9 of 10 – Unacceptable conduct scenario

The code of conduct applies to internal assessors, students assisting under supervision and external security professionals. Technical skill does not provide permission by itself. The engagement letter and rules of engagement define the limits within which testing is permitted.

The ethical standard is stricter than a minimum technical permission. Testers must minimise access to personal information, avoid unnecessary service impact, preserve evidence, report honestly and stop when the activity moves outside the approved boundary.

Written permission

Before any test, the assessor must have a signed authorization from a person with delegated authority. The authorization names the engagement, assets, dates, testing team and approved methods. If the target is owned by a supplier or cloud provider, the relevant contractual permission must also be checked. An email from a technical contact is not enough unless the university's approval process recognises that person as an authorized signatory.

Confidentiality

Assessors may encounter names, contact details, grades, identity information, research data or credentials. They should avoid collecting real records when a synthetic account or test dataset is sufficient. If sensitive content is unexpectedly exposed, the assessor must stop further access, record only the minimum evidence needed and contact the designated privacy or security lead.

Practical design points

- Record the decision for 'unacceptable conduct scenario' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Principle	Required behaviour	Control / evidence
Authorization	Test only after written approval	Signed authorization ID
Confidentiality	Minimise access and protect evidence	Restricted evidence folder
Integrity	Report facts accurately	Time-stamped logs
Avoid harm	Use low-impact methods and stop on instability	Stop-work log
Accountability	Identify who performed each action	Assessor activity record

Process view

Authorization → Ethical checks → Controlled testing → Evidence review → Honest report

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 3 – CREATE AN ETHICS AND CODE-OF-CONDUCT MODULE

Page 10 of 10 – Code-of-conduct audit and conclusion

The code of conduct applies to internal assessors, students assisting under supervision and external security professionals. Technical skill does not provide permission by itself. The engagement letter and rules of engagement define the limits within which testing is permitted.

The ethical standard is stricter than a minimum technical permission. Testers must minimise access to personal information, avoid unnecessary service impact, preserve evidence, report honestly and stop when the activity moves outside the approved boundary.

Confidentiality

Assessors may encounter names, contact details, grades, identity information, research data or credentials. They should avoid collecting real records when a synthetic account or test dataset is sufficient. If sensitive content is unexpectedly exposed, the assessor must stop further access, record only the minimum evidence needed and contact the designated privacy or security lead.

Integrity and honesty

Evidence must be accurate, time-stamped and linked to the engagement ID. Screenshots and logs should not be altered to make a finding appear more severe. Reports distinguish confirmed facts from assumptions and recommendations. A tester must disclose failed tests, tool errors and limitations rather than presenting incomplete work as a complete assessment.

Practical design points

- Record the decision for 'code-of-conduct audit and conclusion' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Principle	Required behaviour	Control / evidence
Authorization	Test only after written approval	Signed authorization ID
Confidentiality	Minimise access and protect evidence	Restricted evidence folder
Integrity	Report facts accurately	Time-stamped logs
Avoid harm	Use low-impact methods and stop on instability	Stop-work log
Accountability	Identify who performed each action	Assessor activity record

Process view

Authorization → Ethical checks → Controlled testing → Evidence review → Honest report

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 4 – CONSTRUCT A LEGAL-COMPLIANCE MAPPING

Page 1 of 10 – Legal context and jurisdiction

The programme is based in India, so the Information Technology Act, 2000 is the principal computer-misuse statute considered in this design. The assignment also asks for comparison with the United States Computer Fraud and Abuse Act (CFAA). The CFAA is a comparative example and does not automatically govern a domestic university engagement.

Legal analysis must distinguish a written authorization from compliance with every applicable law. A signed document cannot legalise conduct prohibited by law, override third-party rights or remove data-protection duties. The university should obtain legal review where facts or jurisdiction are uncertain.

Section 43

Section 43 of the Information Technology Act addresses specified acts involving computer resources carried out without permission, including access, copying or extraction of data, introducing contaminants, disruption and denial of access. The programme therefore requires clear permission from the owner or authorized person and controls against activity outside that permission. The section's civil penalty/compensation framework must be distinguished from criminal liability under Section 66.

Section 66

Section 66 applies where an act referred to in Section 43 is done dishonestly or fraudulently. The statutory text provides for imprisonment up to three years, or a fine up to five lakh rupees, or both. This is why authorization, purpose limitation and evidence of the assessor's permitted activity are essential. A tester must not assume that a security-testing label is a defence for conduct outside the authorization.

Practical design points

- Record the decision for 'legal context and jurisdiction' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Law / provision	Relevance to engagement	Framework control
IT Act, s.43	Unauthorized access or interference can attract civil liability	Explicit owner permission and exact scope
IT Act, s.66	Dishonest or fraudulent s.43 acts are criminal offences	Purpose, authorization and audit trail
IT Act, s.72 / 72A	Confidentiality and contractual disclosure issues	Least privilege and confidentiality terms
DPDP Act / Rules	Digital personal data processing obligations as provisions commence	Data minimisation and privacy review
US CFAA, 18 USC 1030	US federal computer access offences; comparative only unless jurisdictional nexus	Jurisdiction review

Process view

Asset and data review → Applicable law check → Control mapping → Approval → Audit evidence

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 4 – CONSTRUCT A LEGAL-COMPLIANCE MAPPING

Page 2 of 10 – Information Technology Act: Section 43

The programme is based in India, so the Information Technology Act, 2000 is the principal computer-misuse statute considered in this design. The assignment also asks for comparison with the United States Computer Fraud and Abuse Act (CFAA). The CFAA is a comparative example and does not automatically govern a domestic university engagement.

Legal analysis must distinguish a written authorization from compliance with every applicable law. A signed document cannot legalise conduct prohibited by law, override third-party rights or remove data-protection duties. The university should obtain legal review where facts or jurisdiction are uncertain.

Section 66

Section 66 applies where an act referred to in Section 43 is done dishonestly or fraudulently. The statutory text provides for imprisonment up to three years, or a fine up to five lakh rupees, or both. This is why authorization, purpose limitation and evidence of the assessor's permitted activity are essential. A tester must not assume that a security-testing label is a defence for conduct outside the authorization.

Confidentiality

Sections 72 and 72A address different confidentiality situations. Section 72 concerns disclosure of specified information obtained under powers under the Act; Section 72A concerns disclosure of personal information in breach of a lawful contract with the required wrongful-loss or wrongful-gain intent/knowledge. Contractual confidentiality, access limitation and controlled reporting are therefore important controls.

Practical design points

- Record the decision for 'information technology act: section 43' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Law / provision	Relevance to engagement	Framework control
IT Act, s.43	Unauthorized access or interference can attract civil liability	Explicit owner permission and exact scope
IT Act, s.66	Dishonest or fraudulent s.43 acts are criminal offences	Purpose, authorization and audit trail
IT Act, s.72 / 72A	Confidentiality and contractual disclosure issues	Least privilege and confidentiality terms
DPDP Act / Rules	Digital personal data processing obligations as provisions commence	Data minimisation and privacy review
US CFAA, 18 USC 1030	US federal computer access offences; comparative only unless jurisdictional nexus	Jurisdiction review

Process view

Asset and data review → Applicable law check → Control mapping → Approval → Audit evidence

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 4 – CONSTRUCT A LEGAL-COMPLIANCE MAPPING

Page 3 of 10 – Information Technology Act: Section 66

The programme is based in India, so the Information Technology Act, 2000 is the principal computer-misuse statute considered in this design. The assignment also asks for comparison with the United States Computer Fraud and Abuse Act (CFAA). The CFAA is a comparative example and does not automatically govern a domestic university engagement.

Legal analysis must distinguish a written authorization from compliance with every applicable law. A signed document cannot legalise conduct prohibited by law, override third-party rights or remove data-protection duties. The university should obtain legal review where facts or jurisdiction are uncertain.

Confidentiality

Sections 72 and 72A address different confidentiality situations. Section 72 concerns disclosure of specified information obtained under powers under the Act; Section 72A concerns disclosure of personal information in breach of a lawful contract with the required wrongful-loss or wrongful-gain intent/knowledge. Contractual confidentiality, access limitation and controlled reporting are therefore important controls.

DPDP and phased commencement

The Digital Personal Data Protection Act, 2023 and the Digital Personal Data Protection Rules, 2025 are relevant to digital personal data. The commencement notification phases provisions over time. The framework should maintain a legal register and check which provisions are in force on the date of each engagement, rather than treating every provision as simultaneously commenced. The university should obtain current legal advice before relying on a specific compliance conclusion.

Practical design points

- Record the decision for 'information technology act: section 66' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Law / provision	Relevance to engagement	Framework control
IT Act, s.43	Unauthorized access or interference can attract civil liability	Explicit owner permission and exact scope
IT Act, s.66	Dishonest or fraudulent s.43 acts are criminal offences	Purpose, authorization and audit trail
IT Act, s.72 / 72A	Confidentiality and contractual disclosure issues	Least privilege and confidentiality terms
DPDP Act / Rules	Digital personal data processing obligations as provisions commence	Data minimisation and privacy review
US CFAA, 18 USC 1030	US federal computer access offences; comparative only unless jurisdictional nexus	Jurisdiction review

Process view

Asset and data review → Applicable law check → Control mapping → Approval → Audit evidence

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 4 – CONSTRUCT A LEGAL-COMPLIANCE MAPPING

Page 4 of 10 – Privacy, confidentiality and contractual duties

The programme is based in India, so the Information Technology Act, 2000 is the principal computer-misuse statute considered in this design. The assignment also asks for comparison with the United States Computer Fraud and Abuse Act (CFAA). The CFAA is a comparative example and does not automatically govern a domestic university engagement.

Legal analysis must distinguish a written authorization from compliance with every applicable law. A signed document cannot legalise conduct prohibited by law, override third-party rights or remove data-protection duties. The university should obtain legal review where facts or jurisdiction are uncertain.

DPDP and phased commencement

The Digital Personal Data Protection Act, 2023 and the Digital Personal Data Protection Rules, 2025 are relevant to digital personal data. The commencement notification phases provisions over time. The framework should maintain a legal register and check which provisions are in force on the date of each engagement, rather than treating every provision as simultaneously commenced. The university should obtain current legal advice before relying on a specific compliance conclusion.

Section 43

Section 43 of the Information Technology Act addresses specified acts involving computer resources carried out without permission, including access, copying or extraction of data, introducing contaminants, disruption and denial of access. The programme therefore requires clear permission from the owner or authorized person and controls against activity outside that permission. The section's civil penalty/compensation framework must be distinguished from criminal liability under Section 66.

Practical design points

- Record the decision for 'privacy, confidentiality and contractual duties' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Law / provision	Relevance to engagement	Framework control
IT Act, s.43	Unauthorized access or interference can attract civil liability	Explicit owner permission and exact scope
IT Act, s.66	Dishonest or fraudulent s.43 acts are criminal offences	Purpose, authorization and audit trail
IT Act, s.72 / 72A	Confidentiality and contractual disclosure issues	Least privilege and confidentiality terms
DPDP Act / Rules	Digital personal data processing obligations as provisions commence	Data minimisation and privacy review
US CFAA, 18 USC 1030	US federal computer access offences; comparative only unless jurisdictional nexus	Jurisdiction review

Process view

Asset and data review → Applicable law check → Control mapping → Approval → Audit evidence

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 4 – CONSTRUCT A LEGAL-COMPLIANCE MAPPING

Page 5 of 10 – DPDP Act and phased commencement

The programme is based in India, so the Information Technology Act, 2000 is the principal computer-misuse statute considered in this design. The assignment also asks for comparison with the United States Computer Fraud and Abuse Act (CFAA). The CFAA is a comparative example and does not automatically govern a domestic university engagement.

Legal analysis must distinguish a written authorization from compliance with every applicable law. A signed document cannot legalise conduct prohibited by law, override third-party rights or remove data-protection duties. The university should obtain legal review where facts or jurisdiction are uncertain.

Section 43

Section 43 of the Information Technology Act addresses specified acts involving computer resources carried out without permission, including access, copying or extraction of data, introducing contaminants, disruption and denial of access. The programme therefore requires clear permission from the owner or authorized person and controls against activity outside that permission. The section's civil penalty/compensation framework must be distinguished from criminal liability under Section 66.

Section 66

Section 66 applies where an act referred to in Section 43 is done dishonestly or fraudulently. The statutory text provides for imprisonment up to three years, or a fine up to five lakh rupees, or both. This is why authorization, purpose limitation and evidence of the assessor's permitted activity are essential. A tester must not assume that a security-testing label is a defence for conduct outside the authorization.

Practical design points

- Record the decision for 'dpdp act and phased commencement' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Law / provision	Relevance to engagement	Framework control
IT Act, s.43	Unauthorized access or interference can attract civil liability	Explicit owner permission and exact scope
IT Act, s.66	Dishonest or fraudulent s.43 acts are criminal offences	Purpose, authorization and audit trail
IT Act, s.72 / 72A	Confidentiality and contractual disclosure issues	Least privilege and confidentiality terms
DPDP Act / Rules	Digital personal data processing obligations as provisions commence	Data minimisation and privacy review
US CFAA, 18 USC 1030	US federal computer access offences; comparative only unless jurisdictional nexus	Jurisdiction review

Process view

Asset and data review → Applicable law check → Control mapping → Approval → Audit evidence

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 4 – CONSTRUCT A LEGAL-COMPLIANCE MAPPING

Page 6 of 10 – CFAA comparison: access and damage

The programme is based in India, so the Information Technology Act, 2000 is the principal computer-misuse statute considered in this design. The assignment also asks for comparison with the United States Computer Fraud and Abuse Act (CFAA). The CFAA is a comparative example and does not automatically govern a domestic university engagement.

Legal analysis must distinguish a written authorization from compliance with every applicable law. A signed document cannot legalise conduct prohibited by law, override third-party rights or remove data-protection duties. The university should obtain legal review where facts or jurisdiction are uncertain.

Section 66

Section 66 applies where an act referred to in Section 43 is done dishonestly or fraudulently. The statutory text provides for imprisonment up to three years, or a fine up to five lakh rupees, or both. This is why authorization, purpose limitation and evidence of the assessor's permitted activity are essential. A tester must not assume that a security-testing label is a defence for conduct outside the authorization.

Confidentiality

Sections 72 and 72A address different confidentiality situations. Section 72 concerns disclosure of specified information obtained under powers under the Act; Section 72A concerns disclosure of personal information in breach of a lawful contract with the required wrongful-loss or wrongful-gain intent/knowledge. Contractual confidentiality, access limitation and controlled reporting are therefore important controls.

Practical design points

- Record the decision for 'cfaa comparison: access and damage' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Law / provision	Relevance to engagement	Framework control
IT Act, s.43	Unauthorized access or interference can attract civil liability	Explicit owner permission and exact scope
IT Act, s.66	Dishonest or fraudulent s.43 acts are criminal offences	Purpose, authorization and audit trail
IT Act, s.72 / 72A	Confidentiality and contractual disclosure issues	Least privilege and confidentiality terms
DPDP Act / Rules	Digital personal data processing obligations as provisions commence	Data minimisation and privacy review
US CFAA, 18 USC 1030	US federal computer access offences; comparative only unless jurisdictional nexus	Jurisdiction review

Process view

Asset and data review → Applicable law check → Control mapping → Approval → Audit evidence

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 4 – CONSTRUCT A LEGAL-COMPLIANCE MAPPING

Page 7 of 10 – Offences, obligations and penalty comparison

The programme is based in India, so the Information Technology Act, 2000 is the principal computer-misuse statute considered in this design. The assignment also asks for comparison with the United States Computer Fraud and Abuse Act (CFAA). The CFAA is a comparative example and does not automatically govern a domestic university engagement.

Legal analysis must distinguish a written authorization from compliance with every applicable law. A signed document cannot legalise conduct prohibited by law, override third-party rights or remove data-protection duties. The university should obtain legal review where facts or jurisdiction are uncertain.

Confidentiality

Sections 72 and 72A address different confidentiality situations. Section 72 concerns disclosure of specified information obtained under powers under the Act; Section 72A concerns disclosure of personal information in breach of a lawful contract with the required wrongful-loss or wrongful-gain intent/knowledge. Contractual confidentiality, access limitation and controlled reporting are therefore important controls.

DPDP and phased commencement

The Digital Personal Data Protection Act, 2023 and the Digital Personal Data Protection Rules, 2025 are relevant to digital personal data. The commencement notification phases provisions over time. The framework should maintain a legal register and check which provisions are in force on the date of each engagement, rather than treating every provision as simultaneously commenced. The university should obtain current legal advice before relying on a specific compliance conclusion.

Practical design points

- Record the decision for 'offences, obligations and penalty comparison' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Law / provision	Relevance to engagement	Framework control
IT Act, s.43	Unauthorized access or interference can attract civil liability	Explicit owner permission and exact scope
IT Act, s.66	Dishonest or fraudulent s.43 acts are criminal offences	Purpose, authorization and audit trail
IT Act, s.72 / 72A	Confidentiality and contractual disclosure issues	Least privilege and confidentiality terms
DPDP Act / Rules	Digital personal data processing obligations as provisions commence	Data minimisation and privacy review
US CFAA, 18 USC 1030	US federal computer access offences; comparative only unless jurisdictional nexus	Jurisdiction review

Process view

Asset and data review → Applicable law check → Control mapping → Approval → Audit evidence

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 4 – CONSTRUCT A LEGAL-COMPLIANCE MAPPING

Page 8 of 10 – Legal control mapping for university tests

The programme is based in India, so the Information Technology Act, 2000 is the principal computer-misuse statute considered in this design. The assignment also asks for comparison with the United States Computer Fraud and Abuse Act (CFAA). The CFAA is a comparative example and does not automatically govern a domestic university engagement.

Legal analysis must distinguish a written authorization from compliance with every applicable law. A signed document cannot legalise conduct prohibited by law, override third-party rights or remove data-protection duties. The university should obtain legal review where facts or jurisdiction are uncertain.

DPDP and phased commencement

The Digital Personal Data Protection Act, 2023 and the Digital Personal Data Protection Rules, 2025 are relevant to digital personal data. The commencement notification phases provisions over time. The framework should maintain a legal register and check which provisions are in force on the date of each engagement, rather than treating every provision as simultaneously commenced. The university should obtain current legal advice before relying on a specific compliance conclusion.

Section 43

Section 43 of the Information Technology Act addresses specified acts involving computer resources carried out without permission, including access, copying or extraction of data, introducing contaminants, disruption and denial of access. The programme therefore requires clear permission from the owner or authorized person and controls against activity outside that permission. The section's civil penalty/compensation framework must be distinguished from criminal liability under Section 66.

Practical design points

- Record the decision for 'legal control mapping for university tests' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Law / provision	Relevance to engagement	Framework control
IT Act, s.43	Unauthorized access or interference can attract civil liability	Explicit owner permission and exact scope
IT Act, s.66	Dishonest or fraudulent s.43 acts are criminal offences	Purpose, authorization and audit trail
IT Act, s.72 / 72A	Confidentiality and contractual disclosure issues	Least privilege and confidentiality terms
DPDP Act / Rules	Digital personal data processing obligations as provisions commence	Data minimisation and privacy review
US CFAA, 18 USC 1030	US federal computer access offences; comparative only unless jurisdictional nexus	Jurisdiction review

Process view

Asset and data review → Applicable law check → Control mapping → Approval → Audit evidence

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 4 – CONSTRUCT A LEGAL-COMPLIANCE MAPPING

Page 9 of 10 – Personal-data decision and legal review

The programme is based in India, so the Information Technology Act, 2000 is the principal computer-misuse statute considered in this design. The assignment also asks for comparison with the United States Computer Fraud and Abuse Act (CFAA). The CFAA is a comparative example and does not automatically govern a domestic university engagement.

Legal analysis must distinguish a written authorization from compliance with every applicable law. A signed document cannot legalise conduct prohibited by law, override third-party rights or remove data-protection duties. The university should obtain legal review where facts or jurisdiction are uncertain.

Section 43

Section 43 of the Information Technology Act addresses specified acts involving computer resources carried out without permission, including access, copying or extraction of data, introducing contaminants, disruption and denial of access. The programme therefore requires clear permission from the owner or authorized person and controls against activity outside that permission. The section's civil penalty/compensation framework must be distinguished from criminal liability under Section 66.

Section 66

Section 66 applies where an act referred to in Section 43 is done dishonestly or fraudulently. The statutory text provides for imprisonment up to three years, or a fine up to five lakh rupees, or both. This is why authorization, purpose limitation and evidence of the assessor's permitted activity are essential. A tester must not assume that a security-testing label is a defence for conduct outside the authorization.

Practical design points

- Record the decision for 'personal-data decision and legal review' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Law / provision	Relevance to engagement	Framework control
IT Act, s.43	Unauthorized access or interference can attract civil liability	Explicit owner permission and exact scope
IT Act, s.66	Dishonest or fraudulent s.43 acts are criminal offences	Purpose, authorization and audit trail
IT Act, s.72 / 72A	Confidentiality and contractual disclosure issues	Least privilege and confidentiality terms
DPDP Act / Rules	Digital personal data processing obligations as provisions commence	Data minimisation and privacy review
US CFAA, 18 USC 1030	US federal computer access offences; comparative only unless jurisdictional nexus	Jurisdiction review

Process view

Asset and data review → Applicable law check → Control mapping → Approval → Audit evidence

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 4 – CONSTRUCT A LEGAL-COMPLIANCE MAPPING

Page 10 of 10 – Compliance evidence and limitations

The programme is based in India, so the Information Technology Act, 2000 is the principal computer-misuse statute considered in this design. The assignment also asks for comparison with the United States Computer Fraud and Abuse Act (CFAA). The CFAA is a comparative example and does not automatically govern a domestic university engagement.

Legal analysis must distinguish a written authorization from compliance with every applicable law. A signed document cannot legalise conduct prohibited by law, override third-party rights or remove data-protection duties. The university should obtain legal review where facts or jurisdiction are uncertain.

Section 66

Section 66 applies where an act referred to in Section 43 is done dishonestly or fraudulently. The statutory text provides for imprisonment up to three years, or a fine up to five lakh rupees, or both. This is why authorization, purpose limitation and evidence of the assessor's permitted activity are essential. A tester must not assume that a security-testing label is a defence for conduct outside the authorization.

Confidentiality

Sections 72 and 72A address different confidentiality situations. Section 72 concerns disclosure of specified information obtained under powers under the Act; Section 72A concerns disclosure of personal information in breach of a lawful contract with the required wrongful-loss or wrongful-gain intent/knowledge. Contractual confidentiality, access limitation and controlled reporting are therefore important controls.

Practical design points

- Record the decision for 'compliance evidence and limitations' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Law / provision	Relevance to engagement	Framework control
IT Act, s.43	Unauthorized access or interference can attract civil liability	Explicit owner permission and exact scope
IT Act, s.66	Dishonest or fraudulent s.43 acts are criminal offences	Purpose, authorization and audit trail
IT Act, s.72 / 72A	Confidentiality and contractual disclosure issues	Least privilege and confidentiality terms
DPDP Act / Rules	Digital personal data processing obligations as provisions commence	Data minimisation and privacy review
US CFAA, 18 USC 1030	US federal computer access offences; comparative only unless jurisdictional nexus	Jurisdiction review

Process view

Asset and data review → Applicable law check → Control mapping → Approval → Audit evidence

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 5 – CREATE A SCOPE AND RULES-OF-ENGAGEMENT DOCUMENT

Page 1 of 10 – Purpose, authority and engagement identity

The scope document translates management approval into operational boundaries. It identifies assets by hostname, IP range, application name, owner and environment. A tester should be able to decide quickly whether a proposed action is within scope.

The rules of engagement are treated as a living controlled document. Any change to assets, dates, methods, suppliers or data access requires review and written approval before work proceeds. Silence or an informal verbal request is not treated as approval.

Asset register

Each in-scope asset is recorded with a unique asset ID, service owner, hostname or application URL, IP range where applicable, environment, business purpose and third-party dependency. For example, a student-portal test may cover a named staging hostname and a specified API endpoint, but not every system reachable from the same network. The scope must be specific enough to prevent accidental expansion.

Exclusions

Out-of-scope items include personal devices, unrelated university services, production databases unless separately approved, third-party infrastructure without provider permission, external IP addresses not listed in the scope and systems belonging to other institutions. A tester who discovers a route to an excluded asset records the observation and stops before interacting with it.

Practical design points

- Record the decision for 'purpose, authority and engagement identity' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Boundary field	Example / rule	Decision
Asset	Named staging portal hostname	In scope only if listed
Window	Approved date and start/end time	No testing outside window
Method	Low-impact authenticated checks	Only methods named in RoE
Exclusion	Unlisted third-party host	Do not probe
Stop condition	Service instability or data exposure	Pause and escalate

Process view

Asset identification → In/out-scope decision → Method and time approval → Testing → Stop / escalate

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 5 – CREATE A SCOPE AND RULES-OF-ENGAGEMENT DOCUMENT

Page 2 of 10 – In-scope university assets

The scope document translates management approval into operational boundaries. It identifies assets by hostname, IP range, application name, owner and environment. A tester should be able to decide quickly whether a proposed action is within scope.

The rules of engagement are treated as a living controlled document. Any change to assets, dates, methods, suppliers or data access requires review and written approval before work proceeds. Silence or an informal verbal request is not treated as approval.

Exclusions

Out-of-scope items include personal devices, unrelated university services, production databases unless separately approved, third-party infrastructure without provider permission, external IP addresses not listed in the scope and systems belonging to other institutions. A tester who discovers a route to an excluded asset records the observation and stops before interacting with it.

Methods

Permitted methods may include passive review, configuration inspection, authenticated checks using test accounts, low-impact vulnerability scanning and manual validation in the isolated lab. Each method is tied to an asset and time window. Any intrusive validation requires a separate risk review and explicit written approval. The safest method that answers the assessment question should be preferred.

Practical design points

- Record the decision for 'in-scope university assets' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Boundary field	Example / rule	Decision
Asset	Named staging portal hostname	In scope only if listed
Window	Approved date and start/end time	No testing outside window
Method	Low-impact authenticated checks	Only methods named in RoE
Exclusion	Unlisted third-party host	Do not probe
Stop condition	Service instability or data exposure	Pause and escalate

Process view

Asset identification → In/out-scope decision → Method and time approval → Testing → Stop / escalate

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 5 – CREATE A SCOPE AND RULES-OF-ENGAGEMENT DOCUMENT

Page 3 of 10 – Out-of-scope assets and exclusions

The scope document translates management approval into operational boundaries. It identifies assets by hostname, IP range, application name, owner and environment. A tester should be able to decide quickly whether a proposed action is within scope.

The rules of engagement are treated as a living controlled document. Any change to assets, dates, methods, suppliers or data access requires review and written approval before work proceeds. Silence or an informal verbal request is not treated as approval.

Methods

Permitted methods may include passive review, configuration inspection, authenticated checks using test accounts, low-impact vulnerability scanning and manual validation in the isolated lab. Each method is tied to an asset and time window. Any intrusive validation requires a separate risk review and explicit written approval. The safest method that answers the assessment question should be preferred.

Stop conditions

The assessor pauses if the system becomes unstable, unexpected personal data appears, a third-party boundary is reached, authorization expires, the owner requests a stop or an incident is suspected. The pause is recorded with time, reason, affected asset and person notified. Work resumes only after a documented decision.

Practical design points

- Record the decision for 'out-of-scope assets and exclusions' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Boundary field	Example / rule	Decision
Asset	Named staging portal hostname	In scope only if listed
Window	Approved date and start/end time	No testing outside window
Method	Low-impact authenticated checks	Only methods named in RoE
Exclusion	Unlisted third-party host	Do not probe
Stop condition	Service instability or data exposure	Pause and escalate

Process view

Asset identification → In/out-scope decision → Method and time approval → Testing → Stop / escalate

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 5 – CREATE A SCOPE AND RULES-OF-ENGAGEMENT DOCUMENT

Page 4 of 10 – Permitted testing methods

The scope document translates management approval into operational boundaries. It identifies assets by hostname, IP range, application name, owner and environment. A tester should be able to decide quickly whether a proposed action is within scope.

The rules of engagement are treated as a living controlled document. Any change to assets, dates, methods, suppliers or data access requires review and written approval before work proceeds. Silence or an informal verbal request is not treated as approval.

Stop conditions

The assessor pauses if the system becomes unstable, unexpected personal data appears, a third-party boundary is reached, authorization expires, the owner requests a stop or an incident is suspected. The pause is recorded with time, reason, affected asset and person notified. Work resumes only after a documented decision.

Asset register

Each in-scope asset is recorded with a unique asset ID, service owner, hostname or application URL, IP range where applicable, environment, business purpose and third-party dependency. For example, a student-portal test may cover a named staging hostname and a specified API endpoint, but not every system reachable from the same network. The scope must be specific enough to prevent accidental expansion.

Practical design points

- Record the decision for 'permitted testing methods' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Boundary field	Example / rule	Decision
Asset	Named staging portal hostname	In scope only if listed
Window	Approved date and start/end time	No testing outside window
Method	Low-impact authenticated checks	Only methods named in RoE
Exclusion	Unlisted third-party host	Do not probe
Stop condition	Service instability or data exposure	Pause and escalate

Process view

Asset identification → In/out-scope decision → Method and time approval → Testing → Stop / escalate

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 5 – CREATE A SCOPE AND RULES-OF-ENGAGEMENT DOCUMENT

Page 5 of 10 – Prohibited methods and safety limits

The scope document translates management approval into operational boundaries. It identifies assets by hostname, IP range, application name, owner and environment. A tester should be able to decide quickly whether a proposed action is within scope.

The rules of engagement are treated as a living controlled document. Any change to assets, dates, methods, suppliers or data access requires review and written approval before work proceeds. Silence or an informal verbal request is not treated as approval.

Asset register

Each in-scope asset is recorded with a unique asset ID, service owner, hostname or application URL, IP range where applicable, environment, business purpose and third-party dependency. For example, a student-portal test may cover a named staging hostname and a specified API endpoint, but not every system reachable from the same network. The scope must be specific enough to prevent accidental expansion.

Exclusions

Out-of-scope items include personal devices, unrelated university services, production databases unless separately approved, third-party infrastructure without provider permission, external IP addresses not listed in the scope and systems belonging to other institutions. A tester who discovers a route to an excluded asset records the observation and stops before interacting with it.

Practical design points

- Record the decision for 'prohibited methods and safety limits' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Boundary field	Example / rule	Decision
Asset	Named staging portal hostname	In scope only if listed
Window	Approved date and start/end time	No testing outside window
Method	Low-impact authenticated checks	Only methods named in RoE
Exclusion	Unlisted third-party host	Do not probe
Stop condition	Service instability or data exposure	Pause and escalate

Process view

Asset identification → In/out-scope decision → Method and time approval → Testing → Stop / escalate

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 5 – CREATE A SCOPE AND RULES-OF-ENGAGEMENT DOCUMENT

Page 6 of 10 – Testing windows and operational coordination

The scope document translates management approval into operational boundaries. It identifies assets by hostname, IP range, application name, owner and environment. A tester should be able to decide quickly whether a proposed action is within scope.

The rules of engagement are treated as a living controlled document. Any change to assets, dates, methods, suppliers or data access requires review and written approval before work proceeds. Silence or an informal verbal request is not treated as approval.

Exclusions

Out-of-scope items include personal devices, unrelated university services, production databases unless separately approved, third-party infrastructure without provider permission, external IP addresses not listed in the scope and systems belonging to other institutions. A tester who discovers a route to an excluded asset records the observation and stops before interacting with it.

Methods

Permitted methods may include passive review, configuration inspection, authenticated checks using test accounts, low-impact vulnerability scanning and manual validation in the isolated lab. Each method is tied to an asset and time window. Any intrusive validation requires a separate risk review and explicit written approval. The safest method that answers the assessment question should be preferred.

Practical design points

- Record the decision for 'testing windows and operational coordination' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Boundary field	Example / rule	Decision
Asset	Named staging portal hostname	In scope only if listed
Window	Approved date and start/end time	No testing outside window
Method	Low-impact authenticated checks	Only methods named in RoE
Exclusion	Unlisted third-party host	Do not probe
Stop condition	Service instability or data exposure	Pause and escalate

Process view

Asset identification → In/out-scope decision → Method and time approval → Testing → Stop / escalate

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 5 – CREATE A SCOPE AND RULES-OF-ENGAGEMENT DOCUMENT

Page 7 of 10 – Authorization verification and expiry

The scope document translates management approval into operational boundaries. It identifies assets by hostname, IP range, application name, owner and environment. A tester should be able to decide quickly whether a proposed action is within scope.

The rules of engagement are treated as a living controlled document. Any change to assets, dates, methods, suppliers or data access requires review and written approval before work proceeds. Silence or an informal verbal request is not treated as approval.

Methods

Permitted methods may include passive review, configuration inspection, authenticated checks using test accounts, low-impact vulnerability scanning and manual validation in the isolated lab. Each method is tied to an asset and time window. Any intrusive validation requires a separate risk review and explicit written approval. The safest method that answers the assessment question should be preferred.

Stop conditions

The assessor pauses if the system becomes unstable, unexpected personal data appears, a third-party boundary is reached, authorization expires, the owner requests a stop or an incident is suspected. The pause is recorded with time, reason, affected asset and person notified. Work resumes only after a documented decision.

Practical design points

- Record the decision for 'authorization verification and expiry' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Boundary field	Example / rule	Decision
Asset	Named staging portal hostname	In scope only if listed
Window	Approved date and start/end time	No testing outside window
Method	Low-impact authenticated checks	Only methods named in RoE
Exclusion	Unlisted third-party host	Do not probe
Stop condition	Service instability or data exposure	Pause and escalate

Process view

Asset identification → In/out-scope decision → Method and time approval → Testing → Stop / escalate

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 5 – CREATE A SCOPE AND RULES-OF-ENGAGEMENT DOCUMENT

Page 8 of 10 – Escalation, stop-work and incident handling

The scope document translates management approval into operational boundaries. It identifies assets by hostname, IP range, application name, owner and environment. A tester should be able to decide quickly whether a proposed action is within scope.

The rules of engagement are treated as a living controlled document. Any change to assets, dates, methods, suppliers or data access requires review and written approval before work proceeds. Silence or an informal verbal request is not treated as approval.

Stop conditions

The assessor pauses if the system becomes unstable, unexpected personal data appears, a third-party boundary is reached, authorization expires, the owner requests a stop or an incident is suspected. The pause is recorded with time, reason, affected asset and person notified. Work resumes only after a documented decision.

Asset register

Each in-scope asset is recorded with a unique asset ID, service owner, hostname or application URL, IP range where applicable, environment, business purpose and third-party dependency. For example, a student-portal test may cover a named staging hostname and a specified API endpoint, but not every system reachable from the same network. The scope must be specific enough to prevent accidental expansion.

Practical design points

- Record the decision for 'escalation, stop-work and incident handling' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Boundary field	Example / rule	Decision
Asset	Named staging portal hostname	In scope only if listed
Window	Approved date and start/end time	No testing outside window
Method	Low-impact authenticated checks	Only methods named in RoE
Exclusion	Unlisted third-party host	Do not probe
Stop condition	Service instability or data exposure	Pause and escalate

Process view

Asset identification → In/out-scope decision → Method and time approval → Testing → Stop / escalate

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 5 – CREATE A SCOPE AND RULES-OF-ENGAGEMENT DOCUMENT

Page 9 of 10 – Pre-engagement checklist derived from RoE

The scope document translates management approval into operational boundaries. It identifies assets by hostname, IP range, application name, owner and environment. A tester should be able to decide quickly whether a proposed action is within scope.

The rules of engagement are treated as a living controlled document. Any change to assets, dates, methods, suppliers or data access requires review and written approval before work proceeds. Silence or an informal verbal request is not treated as approval.

Asset register

Each in-scope asset is recorded with a unique asset ID, service owner, hostname or application URL, IP range where applicable, environment, business purpose and third-party dependency. For example, a student-portal test may cover a named staging hostname and a specified API endpoint, but not every system reachable from the same network. The scope must be specific enough to prevent accidental expansion.

Exclusions

Out-of-scope items include personal devices, unrelated university services, production databases unless separately approved, third-party infrastructure without provider permission, external IP addresses not listed in the scope and systems belonging to other institutions. A tester who discovers a route to an excluded asset records the observation and stops before interacting with it.

Practical design points

- Record the decision for 'pre-engagement checklist derived from roe' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Boundary field	Example / rule	Decision
Asset	Named staging portal hostname	In scope only if listed
Window	Approved date and start/end time	No testing outside window
Method	Low-impact authenticated checks	Only methods named in RoE
Exclusion	Unlisted third-party host	Do not probe
Stop condition	Service instability or data exposure	Pause and escalate

Process view

Asset identification → In/out-scope decision → Method and time approval → Testing → Stop / escalate

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 5 – CREATE A SCOPE AND RULES-OF-ENGAGEMENT DOCUMENT

Page 10 of 10 – RoE approval, change control and conclusion

The scope document translates management approval into operational boundaries. It identifies assets by hostname, IP range, application name, owner and environment. A tester should be able to decide quickly whether a proposed action is within scope.

The rules of engagement are treated as a living controlled document. Any change to assets, dates, methods, suppliers or data access requires review and written approval before work proceeds. Silence or an informal verbal request is not treated as approval.

Exclusions

Out-of-scope items include personal devices, unrelated university services, production databases unless separately approved, third-party infrastructure without provider permission, external IP addresses not listed in the scope and systems belonging to other institutions. A tester who discovers a route to an excluded asset records the observation and stops before interacting with it.

Methods

Permitted methods may include passive review, configuration inspection, authenticated checks using test accounts, low-impact vulnerability scanning and manual validation in the isolated lab. Each method is tied to an asset and time window. Any intrusive validation requires a separate risk review and explicit written approval. The safest method that answers the assessment question should be preferred.

Practical design points

- Record the decision for 'roe approval, change control and conclusion' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Boundary field	Example / rule	Decision
Asset	Named staging portal hostname	In scope only if listed
Window	Approved date and start/end time	No testing outside window
Method	Low-impact authenticated checks	Only methods named in RoE
Exclusion	Unlisted third-party host	Do not probe
Stop condition	Service instability or data exposure	Pause and escalate

Process view

Asset identification → In/out-scope decision → Method and time approval → Testing → Stop / escalate

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 6 – BUILD AN AUTHORIZATION AND DISCLOSURE LAYER

Page 1 of 10 – Authorization lifecycle and control objectives

Authorization and disclosure form the programme's control plane. Authorization establishes who may test which assets and when. Disclosure ensures that a finding reaches the correct owner, is handled confidentially and is tracked through remediation and verification.

The preferred default is coordinated disclosure: the university receives a private report, validates the issue, agrees remediation actions and coordinates any later public communication. Public release is not a tester's unilateral decision.

Request intake

A request records the business reason, requested systems, service owner, desired dates, assessor identity, third-party involvement, data sensitivity and expected outputs. The coordinator checks that the request is complete and assigns an engagement ID. Incomplete requests are returned rather than informally approved. A risk rating helps decide whether privacy, legal or senior management review is required.

Approval and sign-off

The system owner confirms the asset boundary and operational window. The security lead checks methods and assessor capability. Privacy staff review the data plan. Legal counsel reviews unusual jurisdiction, supplier or personal-data issues. The delegated sponsor signs the authorization. The signed record is stored in a restricted register with version, date, expiry and change history.

Practical design points

- Record the decision for 'authorization lifecycle and control objectives' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Stage	Responsible role	Required record
Request	Requesting department	Completed request form
Review	Security / system owner / privacy	Risk and scope review
Approval	Delegated sponsor	Signed authorization
Disclosure	Security lead and system owner	Finding and disclosure log
Closure	Owner and coordinator	Retest and closure record

Process view

Request → Approval → Signed record → Assessment → Private finding → Remediation → Closure

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 6 – BUILD AN AUTHORIZATION AND DISCLOSURE LAYER

Page 2 of 10 – Request intake and completeness review

Authorization and disclosure form the programme's control plane. Authorization establishes who may test which assets and when. Disclosure ensures that a finding reaches the correct owner, is handled confidentially and is tracked through remediation and verification.

The preferred default is coordinated disclosure: the university receives a private report, validates the issue, agrees remediation actions and coordinates any later public communication. Public release is not a tester's unilateral decision.

Approval and sign-off

The system owner confirms the asset boundary and operational window. The security lead checks methods and assessor capability. Privacy staff review the data plan. Legal counsel reviews unusual jurisdiction, supplier or personal-data issues. The delegated sponsor signs the authorization. The signed record is stored in a restricted register with version, date, expiry and change history.

Disclosure stages

A finding moves through reported, acknowledged, triaged, validated, remediation assigned, fix implemented, retested and closed. The report contains a short summary, affected asset, evidence, impact, severity rationale, reproduction conditions in a safe lab, mitigation and contact details. The public disclosure date is not promised until the university and reporter have coordinated a safe plan.

Practical design points

- Record the decision for 'request intake and completeness review' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Stage	Responsible role	Required record
Request	Requesting department	Completed request form
Review	Security / system owner / privacy	Risk and scope review
Approval	Delegated sponsor	Signed authorization
Disclosure	Security lead and system owner	Finding and disclosure log
Closure	Owner and coordinator	Retest and closure record

Process view

Request → Approval → Signed record → Assessment → Private finding → Remediation → Closure

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 6 – BUILD AN AUTHORIZATION AND DISCLOSURE LAYER

Page 3 of 10 – Approval roles and written sign-off

Authorization and disclosure form the programme's control plane. Authorization establishes who may test which assets and when. Disclosure ensures that a finding reaches the correct owner, is handled confidentially and is tracked through remediation and verification.

The preferred default is coordinated disclosure: the university receives a private report, validates the issue, agrees remediation actions and coordinates any later public communication. Public release is not a tester's unilateral decision.

Disclosure stages

A finding moves through reported, acknowledged, triaged, validated, remediation assigned, fix implemented, retested and closed. The report contains a short summary, affected asset, evidence, impact, severity rationale, reproduction conditions in a safe lab, mitigation and contact details. The public disclosure date is not promised until the university and reporter have coordinated a safe plan.

Alternative approaches

Full disclosure publishes technical details openly and may increase pressure to fix an issue, but can expose users before a patch is available. A bug bounty provides defined reporting rules and rewards, but requires programme scope, triage capacity and clear payment terms. Coordinated disclosure is selected as the default because the university controls sensitive student services and needs time to remediate.

Practical design points

- Record the decision for 'approval roles and written sign-off' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Stage	Responsible role	Required record
Request	Requesting department	Completed request form
Review	Security / system owner / privacy	Risk and scope review
Approval	Delegated sponsor	Signed authorization
Disclosure	Security lead and system owner	Finding and disclosure log
Closure	Owner and coordinator	Retest and closure record

Process view

Request → Approval → Signed record → Assessment → Private finding → Remediation → Closure

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 6 – BUILD AN AUTHORIZATION AND DISCLOSURE LAYER

Page 4 of 10 – Authorization register and audit logging

Authorization and disclosure form the programme's control plane. Authorization establishes who may test which assets and when. Disclosure ensures that a finding reaches the correct owner, is handled confidentially and is tracked through remediation and verification.

The preferred default is coordinated disclosure: the university receives a private report, validates the issue, agrees remediation actions and coordinates any later public communication. Public release is not a tester's unilateral decision.

Alternative approaches

Full disclosure publishes technical details openly and may increase pressure to fix an issue, but can expose users before a patch is available. A bug bounty provides defined reporting rules and rewards, but requires programme scope, triage capacity and clear payment terms. Coordinated disclosure is selected as the default because the university controls sensitive student services and needs time to remediate.

Request intake

A request records the business reason, requested systems, service owner, desired dates, assessor identity, third-party involvement, data sensitivity and expected outputs. The coordinator checks that the request is complete and assigns an engagement ID. Incomplete requests are returned rather than informally approved. A risk rating helps decide whether privacy, legal or senior management review is required.

Practical design points

- Record the decision for 'authorization register and audit logging' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Stage	Responsible role	Required record
Request	Requesting department	Completed request form
Review	Security / system owner / privacy	Risk and scope review
Approval	Delegated sponsor	Signed authorization
Disclosure	Security lead and system owner	Finding and disclosure log
Closure	Owner and coordinator	Retest and closure record

Process view

Request → Approval → Signed record → Assessment → Private finding → Remediation → Closure

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 6 – BUILD AN AUTHORIZATION AND DISCLOSURE LAYER

Page 5 of 10 – Finding intake and severity assessment

Authorization and disclosure form the programme's control plane. Authorization establishes who may test which assets and when. Disclosure ensures that a finding reaches the correct owner, is handled confidentially and is tracked through remediation and verification.

The preferred default is coordinated disclosure: the university receives a private report, validates the issue, agrees remediation actions and coordinates any later public communication. Public release is not a tester's unilateral decision.

Request intake

A request records the business reason, requested systems, service owner, desired dates, assessor identity, third-party involvement, data sensitivity and expected outputs. The coordinator checks that the request is complete and assigns an engagement ID. Incomplete requests are returned rather than informally approved. A risk rating helps decide whether privacy, legal or senior management review is required.

Approval and sign-off

The system owner confirms the asset boundary and operational window. The security lead checks methods and assessor capability. Privacy staff review the data plan. Legal counsel reviews unusual jurisdiction, supplier or personal-data issues. The delegated sponsor signs the authorization. The signed record is stored in a restricted register with version, date, expiry and change history.

Practical design points

- Record the decision for 'finding intake and severity assessment' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Stage	Responsible role	Required record
Request	Requesting department	Completed request form
Review	Security / system owner / privacy	Risk and scope review
Approval	Delegated sponsor	Signed authorization
Disclosure	Security lead and system owner	Finding and disclosure log
Closure	Owner and coordinator	Retest and closure record

Process view

Request → Approval → Signed record → Assessment → Private finding → Remediation → Closure

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 6 – BUILD AN AUTHORIZATION AND DISCLOSURE LAYER

Page 6 of 10 – Coordinated disclosure workflow

Authorization and disclosure form the programme's control plane. Authorization establishes who may test which assets and when. Disclosure ensures that a finding reaches the correct owner, is handled confidentially and is tracked through remediation and verification.

The preferred default is coordinated disclosure: the university receives a private report, validates the issue, agrees remediation actions and coordinates any later public communication. Public release is not a tester's unilateral decision.

Approval and sign-off

The system owner confirms the asset boundary and operational window. The security lead checks methods and assessor capability. Privacy staff review the data plan. Legal counsel reviews unusual jurisdiction, supplier or personal-data issues. The delegated sponsor signs the authorization. The signed record is stored in a restricted register with version, date, expiry and change history.

Disclosure stages

A finding moves through reported, acknowledged, triaged, validated, remediation assigned, fix implemented, retested and closed. The report contains a short summary, affected asset, evidence, impact, severity rationale, reproduction conditions in a safe lab, mitigation and contact details. The public disclosure date is not promised until the university and reporter have coordinated a safe plan.

Practical design points

- Record the decision for 'coordinated disclosure workflow' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Stage	Responsible role	Required record
Request	Requesting department	Completed request form
Review	Security / system owner / privacy	Risk and scope review
Approval	Delegated sponsor	Signed authorization
Disclosure	Security lead and system owner	Finding and disclosure log
Closure	Owner and coordinator	Retest and closure record

Process view

Request → Approval → Signed record → Assessment → Private finding → Remediation → Closure

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 6 – BUILD AN AUTHORIZATION AND DISCLOSURE LAYER

Page 7 of 10 – Reporting format and remediation timeline

Authorization and disclosure form the programme's control plane. Authorization establishes who may test which assets and when. Disclosure ensures that a finding reaches the correct owner, is handled confidentially and is tracked through remediation and verification.

The preferred default is coordinated disclosure: the university receives a private report, validates the issue, agrees remediation actions and coordinates any later public communication. Public release is not a tester's unilateral decision.

Disclosure stages

A finding moves through reported, acknowledged, triaged, validated, remediation assigned, fix implemented, retested and closed. The report contains a short summary, affected asset, evidence, impact, severity rationale, reproduction conditions in a safe lab, mitigation and contact details. The public disclosure date is not promised until the university and reporter have coordinated a safe plan.

Alternative approaches

Full disclosure publishes technical details openly and may increase pressure to fix an issue, but can expose users before a patch is available. A bug bounty provides defined reporting rules and rewards, but requires programme scope, triage capacity and clear payment terms. Coordinated disclosure is selected as the default because the university controls sensitive student services and needs time to remediate.

Practical design points

- Record the decision for 'reporting format and remediation timeline' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Stage	Responsible role	Required record
Request	Requesting department	Completed request form
Review	Security / system owner / privacy	Risk and scope review
Approval	Delegated sponsor	Signed authorization
Disclosure	Security lead and system owner	Finding and disclosure log
Closure	Owner and coordinator	Retest and closure record

Process view

Request → Approval → Signed record → Assessment → Private finding → Remediation → Closure

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 6 – BUILD AN AUTHORIZATION AND DISCLOSURE LAYER

Page 8 of 10 – Coordinated disclosure versus alternatives

Authorization and disclosure form the programme's control plane. Authorization establishes who may test which assets and when. Disclosure ensures that a finding reaches the correct owner, is handled confidentially and is tracked through remediation and verification.

The preferred default is coordinated disclosure: the university receives a private report, validates the issue, agrees remediation actions and coordinates any later public communication. Public release is not a tester's unilateral decision.

Alternative approaches

Full disclosure publishes technical details openly and may increase pressure to fix an issue, but can expose users before a patch is available. A bug bounty provides defined reporting rules and rewards, but requires programme scope, triage capacity and clear payment terms. Coordinated disclosure is selected as the default because the university controls sensitive student services and needs time to remediate.

Request intake

A request records the business reason, requested systems, service owner, desired dates, assessor identity, third-party involvement, data sensitivity and expected outputs. The coordinator checks that the request is complete and assigns an engagement ID. Incomplete requests are returned rather than informally approved. A risk rating helps decide whether privacy, legal or senior management review is required.

Practical design points

- Record the decision for 'coordinated disclosure versus alternatives' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Stage	Responsible role	Required record
Request	Requesting department	Completed request form
Review	Security / system owner / privacy	Risk and scope review
Approval	Delegated sponsor	Signed authorization
Disclosure	Security lead and system owner	Finding and disclosure log
Closure	Owner and coordinator	Retest and closure record

Process view

Request → Approval → Signed record → Assessment → Private finding → Remediation → Closure

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 6 – BUILD AN AUTHORIZATION AND DISCLOSURE LAYER

Page 9 of 10 – Disclosure decision rules and escalation

Authorization and disclosure form the programme's control plane. Authorization establishes who may test which assets and when. Disclosure ensures that a finding reaches the correct owner, is handled confidentially and is tracked through remediation and verification.

The preferred default is coordinated disclosure: the university receives a private report, validates the issue, agrees remediation actions and coordinates any later public communication. Public release is not a tester's unilateral decision.

Request intake

A request records the business reason, requested systems, service owner, desired dates, assessor identity, third-party involvement, data sensitivity and expected outputs. The coordinator checks that the request is complete and assigns an engagement ID. Incomplete requests are returned rather than informally approved. A risk rating helps decide whether privacy, legal or senior management review is required.

Approval and sign-off

The system owner confirms the asset boundary and operational window. The security lead checks methods and assessor capability. Privacy staff review the data plan. Legal counsel reviews unusual jurisdiction, supplier or personal-data issues. The delegated sponsor signs the authorization. The signed record is stored in a restricted register with version, date, expiry and change history.

Practical design points

- Record the decision for 'disclosure decision rules and escalation' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Stage	Responsible role	Required record
Request	Requesting department	Completed request form
Review	Security / system owner / privacy	Risk and scope review
Approval	Delegated sponsor	Signed authorization
Disclosure	Security lead and system owner	Finding and disclosure log
Closure	Owner and coordinator	Retest and closure record

Process view

Request → Approval → Signed record → Assessment → Private finding → Remediation → Closure

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 6 – BUILD AN AUTHORIZATION AND DISCLOSURE LAYER

Page 10 of 10 – Integration test with RoE and legal controls

Authorization and disclosure form the programme's control plane. Authorization establishes who may test which assets and when. Disclosure ensures that a finding reaches the correct owner, is handled confidentially and is tracked through remediation and verification.

The preferred default is coordinated disclosure: the university receives a private report, validates the issue, agrees remediation actions and coordinates any later public communication. Public release is not a tester's unilateral decision.

Approval and sign-off

The system owner confirms the asset boundary and operational window. The security lead checks methods and assessor capability. Privacy staff review the data plan. Legal counsel reviews unusual jurisdiction, supplier or personal-data issues. The delegated sponsor signs the authorization. The signed record is stored in a restricted register with version, date, expiry and change history.

Disclosure stages

A finding moves through reported, acknowledged, triaged, validated, remediation assigned, fix implemented, retested and closed. The report contains a short summary, affected asset, evidence, impact, severity rationale, reproduction conditions in a safe lab, mitigation and contact details. The public disclosure date is not promised until the university and reporter have coordinated a safe plan.

Practical design points

- Record the decision for 'integration test with roe and legal controls' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Stage	Responsible role	Required record
Request	Requesting department	Completed request form
Review	Security / system owner / privacy	Risk and scope review
Approval	Delegated sponsor	Signed authorization
Disclosure	Security lead and system owner	Finding and disclosure log
Closure	Owner and coordinator	Retest and closure record

Process view

Request → Approval → Signed record → Assessment → Private finding → Remediation → Closure

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 7 – DESIGN AN ISOLATED ETHICAL-HACKING LAB

Page 1 of 10 – Lab purpose and safety architecture

The lab is a controlled environment for hands-on learning and validation. It uses a Kali Linux virtual machine and one or more intentionally selected target machines connected through a host-only network such as 192.168.56.0/24.

A host-only design is selected because the assessment activity should remain inside a private virtual network. The lab is not a substitute for authorization to test production systems, and successful lab testing does not grant permission to scan campus systems.

Components

The proposed lab contains a host computer, hypervisor, Kali Linux virtual machine, one or more intentionally vulnerable target virtual machines, virtual network adapter, snapshots and a lab evidence folder. The Kali machine performs approved learning exercises. The target machine is deliberately configured for practice and contains no real student or staff data.

Network plan

Use a host-only virtual network with a reserved private range such as 192.168.56.0/24. Example addresses are Kali 192.168.56.10/24 and target 192.168.56.20/24. These are planning examples and must be checked against the hypervisor's actual configuration before use. The host-only segment does not provide ordinary external network access by default.

Practical design points

- Record the decision for 'lab purpose and safety architecture' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Example configuration	Purpose
Kali VM	192.168.56.10/24	Authorized test workstation
Target VM	192.168.56.20/24	Intentionally vulnerable practice target
Virtual switch	Host-only 192.168.56.0/24	Contain lab traffic
Snapshots	Baseline and clean-state snapshot	Repeatability and recovery
Evidence folder	Engagement ID / date / logs	Configuration record

Process view

Configure VMs → Host-only network → Verify isolation → Exercise → Save evidence → Revert snapshot

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 7 – DESIGN AN ISOLATED ETHICAL-HACKING LAB

Page 2 of 10 – Virtual machines and component roles

The lab is a controlled environment for hands-on learning and validation. It uses a Kali Linux virtual machine and one or more intentionally selected target machines connected through a host-only network such as 192.168.56.0/24.

A host-only design is selected because the assessment activity should remain inside a private virtual network. The lab is not a substitute for authorization to test production systems, and successful lab testing does not grant permission to scan campus systems.

Network plan

Use a host-only virtual network with a reserved private range such as 192.168.56.0/24. Example addresses are Kali 192.168.56.10/24 and target 192.168.56.20/24. These are planning examples and must be checked against the hypervisor's actual configuration before use. The host-only segment does not provide ordinary external network access by default.

Verification

Before an exercise, record the VM names, operating-system versions, adapter mode, IP addresses, snapshot identifier and date. Verify that the two lab machines can reach each other using a simple connectivity check. Confirm that the target is the intended lab machine. If a route or adapter unexpectedly connects to a production network, stop and correct the configuration.

Practical design points

- Record the decision for 'virtual machines and component roles' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Example configuration	Purpose
Kali VM	192.168.56.10/24	Authorized test workstation
Target VM	192.168.56.20/24	Intentionally vulnerable practice target
Virtual switch	Host-only 192.168.56.0/24	Contain lab traffic
Snapshots	Baseline and clean-state snapshot	Repeatability and recovery
Evidence folder	Engagement ID / date / logs	Configuration record

Process view

Configure VMs → Host-only network → Verify isolation → Exercise → Save evidence → Revert snapshot

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 7 – DESIGN AN ISOLATED ETHICAL-HACKING LAB

Page 3 of 10 – Host-only network topology

The lab is a controlled environment for hands-on learning and validation. It uses a Kali Linux virtual machine and one or more intentionally selected target machines connected through a host-only network such as 192.168.56.0/24.

A host-only design is selected because the assessment activity should remain inside a private virtual network. The lab is not a substitute for authorization to test production systems, and successful lab testing does not grant permission to scan campus systems.

Verification

Before an exercise, record the VM names, operating-system versions, adapter mode, IP addresses, snapshot identifier and date. Verify that the two lab machines can reach each other using a simple connectivity check. Confirm that the target is the intended lab machine. If a route or adapter unexpectedly connects to a production network, stop and correct the configuration.

Reset and containment

Snapshots provide a known clean state for repeatable exercises. Shared folders, clipboard sharing and bridged adapters should be disabled unless a specific need is approved. Lab evidence should contain synthetic data only. At the end of an exercise, save the required evidence, revert the snapshot and record completion.

Practical design points

- Record the decision for 'host-only network topology' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Example configuration	Purpose
Kali VM	192.168.56.10/24	Authorized test workstation
Target VM	192.168.56.20/24	Intentionally vulnerable practice target
Virtual switch	Host-only 192.168.56.0/24	Contain lab traffic
Snapshots	Baseline and clean-state snapshot	Repeatability and recovery
Evidence folder	Engagement ID / date / logs	Configuration record

Process view

Configure VMs → Host-only network → Verify isolation → Exercise → Save evidence → Revert snapshot

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 7 – DESIGN AN ISOLATED ETHICAL-HACKING LAB

Page 4 of 10 – Address plan and network boundaries

The lab is a controlled environment for hands-on learning and validation. It uses a Kali Linux virtual machine and one or more intentionally selected target machines connected through a host-only network such as 192.168.56.0/24.

A host-only design is selected because the assessment activity should remain inside a private virtual network. The lab is not a substitute for authorization to test production systems, and successful lab testing does not grant permission to scan campus systems.

Reset and containment

Snapshots provide a known clean state for repeatable exercises. Shared folders, clipboard sharing and bridged adapters should be disabled unless a specific need is approved. Lab evidence should contain synthetic data only. At the end of an exercise, save the required evidence, revert the snapshot and record completion.

Components

The proposed lab contains a host computer, hypervisor, Kali Linux virtual machine, one or more intentionally vulnerable target virtual machines, virtual network adapter, snapshots and a lab evidence folder. The Kali machine performs approved learning exercises. The target machine is deliberately configured for practice and contains no real student or staff data.

Practical design points

- Record the decision for 'address plan and network boundaries' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Example configuration	Purpose
Kali VM	192.168.56.10/24	Authorized test workstation
Target VM	192.168.56.20/24	Intentionally vulnerable practice target
Virtual switch	Host-only 192.168.56.0/24	Contain lab traffic
Snapshots	Baseline and clean-state snapshot	Repeatability and recovery
Evidence folder	Engagement ID / date / logs	Configuration record

Process view

Configure VMs → Host-only network → Verify isolation → Exercise → Save evidence → Revert snapshot

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 7 – DESIGN AN ISOLATED ETHICAL-HACKING LAB

Page 5 of 10 – Configuration recording and baseline

The lab is a controlled environment for hands-on learning and validation. It uses a Kali Linux virtual machine and one or more intentionally selected target machines connected through a host-only network such as 192.168.56.0/24.

A host-only design is selected because the assessment activity should remain inside a private virtual network. The lab is not a substitute for authorization to test production systems, and successful lab testing does not grant permission to scan campus systems.

Components

The proposed lab contains a host computer, hypervisor, Kali Linux virtual machine, one or more intentionally vulnerable target virtual machines, virtual network adapter, snapshots and a lab evidence folder. The Kali machine performs approved learning exercises. The target machine is deliberately configured for practice and contains no real student or staff data.

Network plan

Use a host-only virtual network with a reserved private range such as 192.168.56.0/24. Example addresses are Kali 192.168.56.10/24 and target 192.168.56.20/24. These are planning examples and must be checked against the hypervisor's actual configuration before use. The host-only segment does not provide ordinary external network access by default.

Practical design points

- Record the decision for 'configuration recording and baseline' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Example configuration	Purpose
Kali VM	192.168.56.10/24	Authorized test workstation
Target VM	192.168.56.20/24	Intentionally vulnerable practice target
Virtual switch	Host-only 192.168.56.0/24	Contain lab traffic
Snapshots	Baseline and clean-state snapshot	Repeatability and recovery
Evidence folder	Engagement ID / date / logs	Configuration record

Process view

Configure VMs → Host-only network → Verify isolation → Exercise → Save evidence → Revert snapshot

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 7 – DESIGN AN ISOLATED ETHICAL-HACKING LAB

Page 6 of 10 – Connectivity verification operation

The lab is a controlled environment for hands-on learning and validation. It uses a Kali Linux virtual machine and one or more intentionally selected target machines connected through a host-only network such as 192.168.56.0/24.

A host-only design is selected because the assessment activity should remain inside a private virtual network. The lab is not a substitute for authorization to test production systems, and successful lab testing does not grant permission to scan campus systems.

Network plan

Use a host-only virtual network with a reserved private range such as 192.168.56.0/24. Example addresses are Kali 192.168.56.10/24 and target 192.168.56.20/24. These are planning examples and must be checked against the hypervisor's actual configuration before use. The host-only segment does not provide ordinary external network access by default.

Verification

Before an exercise, record the VM names, operating-system versions, adapter mode, IP addresses, snapshot identifier and date. Verify that the two lab machines can reach each other using a simple connectivity check. Confirm that the target is the intended lab machine. If a route or adapter unexpectedly connects to a production network, stop and correct the configuration.

Practical design points

- Record the decision for 'connectivity verification operation' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Example configuration	Purpose
Kali VM	192.168.56.10/24	Authorized test workstation
Target VM	192.168.56.20/24	Intentionally vulnerable practice target
Virtual switch	Host-only 192.168.56.0/24	Contain lab traffic
Snapshots	Baseline and clean-state snapshot	Repeatability and recovery
Evidence folder	Engagement ID / date / logs	Configuration record

Process view

Configure VMs → Host-only network → Verify isolation → Exercise → Save evidence → Revert snapshot

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 7 – DESIGN AN ISOLATED ETHICAL-HACKING LAB

Page 7 of 10 – Lab evidence and repeatability operation

The lab is a controlled environment for hands-on learning and validation. It uses a Kali Linux virtual machine and one or more intentionally selected target machines connected through a host-only network such as 192.168.56.0/24.

A host-only design is selected because the assessment activity should remain inside a private virtual network. The lab is not a substitute for authorization to test production systems, and successful lab testing does not grant permission to scan campus systems.

Verification

Before an exercise, record the VM names, operating-system versions, adapter mode, IP addresses, snapshot identifier and date. Verify that the two lab machines can reach each other using a simple connectivity check. Confirm that the target is the intended lab machine. If a route or adapter unexpectedly connects to a production network, stop and correct the configuration.

Reset and containment

Snapshots provide a known clean state for repeatable exercises. Shared folders, clipboard sharing and bridged adapters should be disabled unless a specific need is approved. Lab evidence should contain synthetic data only. At the end of an exercise, save the required evidence, revert the snapshot and record completion.

Practical design points

- Record the decision for 'lab evidence and repeatability operation' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Example configuration	Purpose
Kali VM	192.168.56.10/24	Authorized test workstation
Target VM	192.168.56.20/24	Intentionally vulnerable practice target
Virtual switch	Host-only 192.168.56.0/24	Contain lab traffic
Snapshots	Baseline and clean-state snapshot	Repeatability and recovery
Evidence folder	Engagement ID / date / logs	Configuration record

Process view

Configure VMs → Host-only network → Verify isolation → Exercise → Save evidence → Revert snapshot

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 7 – DESIGN AN ISOLATED ETHICAL-HACKING LAB

Page 8 of 10 – Host-only versus NAT comparison

The lab is a controlled environment for hands-on learning and validation. It uses a Kali Linux virtual machine and one or more intentionally selected target machines connected through a host-only network such as 192.168.56.0/24.

A host-only design is selected because the assessment activity should remain inside a private virtual network. The lab is not a substitute for authorization to test production systems, and successful lab testing does not grant permission to scan campus systems.

Reset and containment

Snapshots provide a known clean state for repeatable exercises. Shared folders, clipboard sharing and bridged adapters should be disabled unless a specific need is approved. Lab evidence should contain synthetic data only. At the end of an exercise, save the required evidence, revert the snapshot and record completion.

Components

The proposed lab contains a host computer, hypervisor, Kali Linux virtual machine, one or more intentionally vulnerable target virtual machines, virtual network adapter, snapshots and a lab evidence folder. The Kali machine performs approved learning exercises. The target machine is deliberately configured for practice and contains no real student or staff data.

Practical design points

- Record the decision for 'host-only versus nat comparison' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Example configuration	Purpose
Kali VM	192.168.56.10/24	Authorized test workstation
Target VM	192.168.56.20/24	Intentionally vulnerable practice target
Virtual switch	Host-only 192.168.56.0/24	Contain lab traffic
Snapshots	Baseline and clean-state snapshot	Repeatability and recovery
Evidence folder	Engagement ID / date / logs	Configuration record

Process view

Configure VMs → Host-only network → Verify isolation → Exercise → Save evidence → Revert snapshot

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 7 – DESIGN AN ISOLATED ETHICAL-HACKING LAB

Page 9 of 10 – Containment, reset and data-handling controls

The lab is a controlled environment for hands-on learning and validation. It uses a Kali Linux virtual machine and one or more intentionally selected target machines connected through a host-only network such as 192.168.56.0/24.

A host-only design is selected because the assessment activity should remain inside a private virtual network. The lab is not a substitute for authorization to test production systems, and successful lab testing does not grant permission to scan campus systems.

Components

The proposed lab contains a host computer, hypervisor, Kali Linux virtual machine, one or more intentionally vulnerable target virtual machines, virtual network adapter, snapshots and a lab evidence folder. The Kali machine performs approved learning exercises. The target machine is deliberately configured for practice and contains no real student or staff data.

Network plan

Use a host-only virtual network with a reserved private range such as 192.168.56.0/24. Example addresses are Kali 192.168.56.10/24 and target 192.168.56.20/24. These are planning examples and must be checked against the hypervisor's actual configuration before use. The host-only segment does not provide ordinary external network access by default.

Practical design points

- Record the decision for 'containment, reset and data-handling controls' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Example configuration	Purpose
Kali VM	192.168.56.10/24	Authorized test workstation
Target VM	192.168.56.20/24	Intentionally vulnerable practice target
Virtual switch	Host-only 192.168.56.0/24	Contain lab traffic
Snapshots	Baseline and clean-state snapshot	Repeatability and recovery
Evidence folder	Engagement ID / date / logs	Configuration record

Process view

Configure VMs → Host-only network → Verify isolation → Exercise → Save evidence → Revert snapshot

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 7 – DESIGN AN ISOLATED ETHICAL-HACKING LAB

Page 10 of 10 – Lab validation and safe-use conclusion

The lab is a controlled environment for hands-on learning and validation. It uses a Kali Linux virtual machine and one or more intentionally selected target machines connected through a host-only network such as 192.168.56.0/24.

A host-only design is selected because the assessment activity should remain inside a private virtual network. The lab is not a substitute for authorization to test production systems, and successful lab testing does not grant permission to scan campus systems.

Network plan

Use a host-only virtual network with a reserved private range such as 192.168.56.0/24. Example addresses are Kali 192.168.56.10/24 and target 192.168.56.20/24. These are planning examples and must be checked against the hypervisor's actual configuration before use. The host-only segment does not provide ordinary external network access by default.

Verification

Before an exercise, record the VM names, operating-system versions, adapter mode, IP addresses, snapshot identifier and date. Verify that the two lab machines can reach each other using a simple connectivity check. Confirm that the target is the intended lab machine. If a route or adapter unexpectedly connects to a production network, stop and correct the configuration.

Practical design points

- Record the decision for 'lab validation and safe-use conclusion' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Example configuration	Purpose
Kali VM	192.168.56.10/24	Authorized test workstation
Target VM	192.168.56.20/24	Intentionally vulnerable practice target
Virtual switch	Host-only 192.168.56.0/24	Contain lab traffic
Snapshots	Baseline and clean-state snapshot	Repeatability and recovery
Evidence folder	Engagement ID / date / logs	Configuration record

Process view

Configure VMs → Host-only network → Verify isolation → Exercise → Save evidence → Revert snapshot

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 8 – DEVELOP A REUSABLE DOCUMENT LIBRARY

Page 1 of 10 – Document library structure and naming

The document library makes the framework repeatable. Each engagement should use standard forms so that approval, scope, evidence, findings and remediation are recorded consistently. Templates include mandatory fields, controlled identifiers and version information.

Structured documents reduce missing information and make handover easier. The finding report is designed to feed the disclosure register and remediation tracker, so the same finding identifier follows the issue from discovery to closure.

Template control

Every template includes a document ID, version, owner, date, engagement ID and retention classification. Required fields are marked clearly. Templates are stored in a restricted location and updated only by the document owner. Old versions remain available for audit but are marked superseded so that assessors do not use them by mistake.

Authorization form

The form records the university sponsor, system owner, assessor names, asset identifiers, approved dates, methods, exclusions, emergency contacts, data restrictions and signatures. It also records the authority under which the signatory approves the work. Missing asset boundaries or missing signatures cause the request to fail validation.

Practical design points

- Record the decision for 'document library structure and naming' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Document	Mandatory fields	Framework connection
Request form	Purpose, owner, assets, dates	Starts authorization workflow
Authorization	Signatures, scope, methods, expiry	Permission gate
RoE	In/out scope, limits, escalation	Controls execution
Finding report	ID, evidence, impact, remediation	Feeds disclosure and remediation

Process view

Template selection → Mandatory-field check → Validation → Controlled storage → Linked register

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 8 – DEVELOP A REUSABLE DOCUMENT LIBRARY

Page 2 of 10 – Engagement request form

The document library makes the framework repeatable. Each engagement should use standard forms so that approval, scope, evidence, findings and remediation are recorded consistently. Templates include mandatory fields, controlled identifiers and version information.

Structured documents reduce missing information and make handover easier. The finding report is designed to feed the disclosure register and remediation tracker, so the same finding identifier follows the issue from discovery to closure.

Authorization form

The form records the university sponsor, system owner, assessor names, asset identifiers, approved dates, methods, exclusions, emergency contacts, data restrictions and signatures. It also records the authority under which the signatory approves the work. Missing asset boundaries or missing signatures cause the request to fail validation.

Finding report

A finding has a unique ID, title, affected asset, discovery date, reporter, severity, evidence reference, impact, safe reproduction summary, recommended remediation, disclosure status and owner. The structured finding ID is reused in the disclosure log and remediation tracker. This avoids multiple inconsistent descriptions of the same issue.

Practical design points

- Record the decision for 'engagement request form' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Document	Mandatory fields	Framework connection
Request form	Purpose, owner, assets, dates	Starts authorization workflow
Authorization	Signatures, scope, methods, expiry	Permission gate
RoE	In/out scope, limits, escalation	Controls execution
Finding report	ID, evidence, impact, remediation	Feeds disclosure and remediation

Process view

Template selection → Mandatory-field check → Validation → Controlled storage → Linked register

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 8 – DEVELOP A REUSABLE DOCUMENT LIBRARY

Page 3 of 10 – Authorization and consent form

The document library makes the framework repeatable. Each engagement should use standard forms so that approval, scope, evidence, findings and remediation are recorded consistently. Templates include mandatory fields, controlled identifiers and version information.

Structured documents reduce missing information and make handover easier. The finding report is designed to feed the disclosure register and remediation tracker, so the same finding identifier follows the issue from discovery to closure.

Finding report

A finding has a unique ID, title, affected asset, discovery date, reporter, severity, evidence reference, impact, safe reproduction summary, recommended remediation, disclosure status and owner. The structured finding ID is reused in the disclosure log and remediation tracker. This avoids multiple inconsistent descriptions of the same issue.

Input validation

A valid test entry contains all mandatory fields and a matching signed authorization. A boundary entry may contain a date at the end of the approved window or a low-severity finding with limited evidence; it should be accepted with a warning or review. An invalid entry omits the signatory, names an excluded asset or uses an expired engagement ID; it must be rejected.

Practical design points

- Record the decision for 'authorization and consent form' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Document	Mandatory fields	Framework connection
Request form	Purpose, owner, assets, dates	Starts authorization workflow
Authorization	Signatures, scope, methods, expiry	Permission gate
RoE	In/out scope, limits, escalation	Controls execution
Finding report	ID, evidence, impact, remediation	Feeds disclosure and remediation

Process view

Template selection → Mandatory-field check → Validation → Controlled storage → Linked register

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 8 – DEVELOP A REUSABLE DOCUMENT LIBRARY

Page 4 of 10 – Rules-of-engagement template

The document library makes the framework repeatable. Each engagement should use standard forms so that approval, scope, evidence, findings and remediation are recorded consistently. Templates include mandatory fields, controlled identifiers and version information.

Structured documents reduce missing information and make handover easier. The finding report is designed to feed the disclosure register and remediation tracker, so the same finding identifier follows the issue from discovery to closure.

Input validation

A valid test entry contains all mandatory fields and a matching signed authorization. A boundary entry may contain a date at the end of the approved window or a low-severity finding with limited evidence; it should be accepted with a warning or review. An invalid entry omits the signatory, names an excluded asset or uses an expired engagement ID; it must be rejected.

Template control

Every template includes a document ID, version, owner, date, engagement ID and retention classification. Required fields are marked clearly. Templates are stored in a restricted location and updated only by the document owner. Old versions remain available for audit but are marked superseded so that assessors do not use them by mistake.

Practical design points

- Record the decision for 'rules-of-engagement template' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Document	Mandatory fields	Framework connection
Request form	Purpose, owner, assets, dates	Starts authorization workflow
Authorization	Signatures, scope, methods, expiry	Permission gate
RoE	In/out scope, limits, escalation	Controls execution
Finding report	ID, evidence, impact, remediation	Feeds disclosure and remediation

Process view

Template selection → Mandatory-field check → Validation → Controlled storage → Linked register

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 8 – DEVELOP A REUSABLE DOCUMENT LIBRARY

Page 5 of 10 – Finding report and structured output

The document library makes the framework repeatable. Each engagement should use standard forms so that approval, scope, evidence, findings and remediation are recorded consistently. Templates include mandatory fields, controlled identifiers and version information.

Structured documents reduce missing information and make handover easier. The finding report is designed to feed the disclosure register and remediation tracker, so the same finding identifier follows the issue from discovery to closure.

Template control

Every template includes a document ID, version, owner, date, engagement ID and retention classification. Required fields are marked clearly. Templates are stored in a restricted location and updated only by the document owner. Old versions remain available for audit but are marked superseded so that assessors do not use them by mistake.

Authorization form

The form records the university sponsor, system owner, assessor names, asset identifiers, approved dates, methods, exclusions, emergency contacts, data restrictions and signatures. It also records the authority under which the signatory approves the work. Missing asset boundaries or missing signatures cause the request to fail validation.

Practical design points

- Record the decision for 'finding report and structured output' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Document	Mandatory fields	Framework connection
Request form	Purpose, owner, assets, dates	Starts authorization workflow
Authorization	Signatures, scope, methods, expiry	Permission gate
RoE	In/out scope, limits, escalation	Controls execution
Finding report	ID, evidence, impact, remediation	Feeds disclosure and remediation

Process view

Template selection → Mandatory-field check → Validation → Controlled storage → Linked register

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 8 – DEVELOP A REUSABLE DOCUMENT LIBRARY

Page 6 of 10 – Evidence log and chain-of-custody record

The document library makes the framework repeatable. Each engagement should use standard forms so that approval, scope, evidence, findings and remediation are recorded consistently. Templates include mandatory fields, controlled identifiers and version information.

Structured documents reduce missing information and make handover easier. The finding report is designed to feed the disclosure register and remediation tracker, so the same finding identifier follows the issue from discovery to closure.

Authorization form

The form records the university sponsor, system owner, assessor names, asset identifiers, approved dates, methods, exclusions, emergency contacts, data restrictions and signatures. It also records the authority under which the signatory approves the work. Missing asset boundaries or missing signatures cause the request to fail validation.

Finding report

A finding has a unique ID, title, affected asset, discovery date, reporter, severity, evidence reference, impact, safe reproduction summary, recommended remediation, disclosure status and owner. The structured finding ID is reused in the disclosure log and remediation tracker. This avoids multiple inconsistent descriptions of the same issue.

Practical design points

- Record the decision for 'evidence log and chain-of-custody record' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Document	Mandatory fields	Framework connection
Request form	Purpose, owner, assets, dates	Starts authorization workflow
Authorization	Signatures, scope, methods, expiry	Permission gate
RoE	In/out scope, limits, escalation	Controls execution
Finding report	ID, evidence, impact, remediation	Feeds disclosure and remediation

Process view

Template selection → Mandatory-field check → Validation → Controlled storage → Linked register

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 8 – DEVELOP A REUSABLE DOCUMENT LIBRARY

Page 7 of 10 – Remediation and retest record

The document library makes the framework repeatable. Each engagement should use standard forms so that approval, scope, evidence, findings and remediation are recorded consistently. Templates include mandatory fields, controlled identifiers and version information.

Structured documents reduce missing information and make handover easier. The finding report is designed to feed the disclosure register and remediation tracker, so the same finding identifier follows the issue from discovery to closure.

Finding report

A finding has a unique ID, title, affected asset, discovery date, reporter, severity, evidence reference, impact, safe reproduction summary, recommended remediation, disclosure status and owner. The structured finding ID is reused in the disclosure log and remediation tracker. This avoids multiple inconsistent descriptions of the same issue.

Input validation

A valid test entry contains all mandatory fields and a matching signed authorization. A boundary entry may contain a date at the end of the approved window or a low-severity finding with limited evidence; it should be accepted with a warning or review. An invalid entry omits the signatory, names an excluded asset or uses an expired engagement ID; it must be rejected.

Practical design points

- Record the decision for 'remediation and retest record' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Document	Mandatory fields	Framework connection
Request form	Purpose, owner, assets, dates	Starts authorization workflow
Authorization	Signatures, scope, methods, expiry	Permission gate
RoE	In/out scope, limits, escalation	Controls execution
Finding report	ID, evidence, impact, remediation	Feeds disclosure and remediation

Process view

Template selection → Mandatory-field check → Validation → Controlled storage → Linked register

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 8 – DEVELOP A REUSABLE DOCUMENT LIBRARY

Page 8 of 10 – Valid, boundary and invalid test entries

The document library makes the framework repeatable. Each engagement should use standard forms so that approval, scope, evidence, findings and remediation are recorded consistently. Templates include mandatory fields, controlled identifiers and version information.

Structured documents reduce missing information and make handover easier. The finding report is designed to feed the disclosure register and remediation tracker, so the same finding identifier follows the issue from discovery to closure.

Input validation

A valid test entry contains all mandatory fields and a matching signed authorization. A boundary entry may contain a date at the end of the approved window or a low-severity finding with limited evidence; it should be accepted with a warning or review. An invalid entry omits the signatory, names an excluded asset or uses an expired engagement ID; it must be rejected.

Template control

Every template includes a document ID, version, owner, date, engagement ID and retention classification. Required fields are marked clearly. Templates are stored in a restricted location and updated only by the document owner. Old versions remain available for audit but are marked superseded so that assessors do not use them by mistake.

Practical design points

- Record the decision for 'valid, boundary and invalid test entries' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Document	Mandatory fields	Framework connection
Request form	Purpose, owner, assets, dates	Starts authorization workflow
Authorization	Signatures, scope, methods, expiry	Permission gate
RoE	In/out scope, limits, escalation	Controls execution
Finding report	ID, evidence, impact, remediation	Feeds disclosure and remediation

Process view

Template selection → Mandatory-field check → Validation → Controlled storage → Linked register

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 8 – DEVELOP A REUSABLE DOCUMENT LIBRARY

Page 9 of 10 – Document integration and version control

The document library makes the framework repeatable. Each engagement should use standard forms so that approval, scope, evidence, findings and remediation are recorded consistently. Templates include mandatory fields, controlled identifiers and version information.

Structured documents reduce missing information and make handover easier. The finding report is designed to feed the disclosure register and remediation tracker, so the same finding identifier follows the issue from discovery to closure.

Template control

Every template includes a document ID, version, owner, date, engagement ID and retention classification. Required fields are marked clearly. Templates are stored in a restricted location and updated only by the document owner. Old versions remain available for audit but are marked superseded so that assessors do not use them by mistake.

Authorization form

The form records the university sponsor, system owner, assessor names, asset identifiers, approved dates, methods, exclusions, emergency contacts, data restrictions and signatures. It also records the authority under which the signatory approves the work. Missing asset boundaries or missing signatures cause the request to fail validation.

Practical design points

- Record the decision for 'document integration and version control' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Document	Mandatory fields	Framework connection
Request form	Purpose, owner, assets, dates	Starts authorization workflow
Authorization	Signatures, scope, methods, expiry	Permission gate
RoE	In/out scope, limits, escalation	Controls execution
Finding report	ID, evidence, impact, remediation	Feeds disclosure and remediation

Process view

Template selection → Mandatory-field check → Validation → Controlled storage → Linked register

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 8 – DEVELOP A REUSABLE DOCUMENT LIBRARY

Page 10 of 10 – Library review and conclusion

The document library makes the framework repeatable. Each engagement should use standard forms so that approval, scope, evidence, findings and remediation are recorded consistently. Templates include mandatory fields, controlled identifiers and version information.

Structured documents reduce missing information and make handover easier. The finding report is designed to feed the disclosure register and remediation tracker, so the same finding identifier follows the issue from discovery to closure.

Authorization form

The form records the university sponsor, system owner, assessor names, asset identifiers, approved dates, methods, exclusions, emergency contacts, data restrictions and signatures. It also records the authority under which the signatory approves the work. Missing asset boundaries or missing signatures cause the request to fail validation.

Finding report

A finding has a unique ID, title, affected asset, discovery date, reporter, severity, evidence reference, impact, safe reproduction summary, recommended remediation, disclosure status and owner. The structured finding ID is reused in the disclosure log and remediation tracker. This avoids multiple inconsistent descriptions of the same issue.

Practical design points

- Record the decision for 'library review and conclusion' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Document	Mandatory fields	Framework connection
Request form	Purpose, owner, assets, dates	Starts authorization workflow
Authorization	Signatures, scope, methods, expiry	Permission gate
RoE	In/out scope, limits, escalation	Controls execution
Finding report	ID, evidence, impact, remediation	Feeds disclosure and remediation

Process view

Template selection → Mandatory-field check → Validation → Controlled storage → Linked register

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 9 – INTEGRATE, TEST AND REFINE THE FRAMEWORK

Page 1 of 10 – Integrated framework overview

Integration is tested through a fictional but realistic university assessment. The walkthrough begins with a department request and ends with a verified remediation and a closure record. No live exploitation is required or performed in this design exercise.

Testing includes positive cases and negative cases. The framework must reject missing authorization, block out-of-scope activity, pause when a legal conflict is identified and escalate when disclosure or remediation deadlines are missed.

Walkthrough case

A department requests a security review of the student portal staging environment before an upgrade. The request is assigned an engagement ID. The owner confirms the staging hostname and test account. The security lead checks methods and schedule. Privacy staff confirm that synthetic records will be used. The sponsor signs the authorization and the RoE is attached.

Execution

The assessor checks the lab baseline first and validates test cases against an isolated target. Any production-facing check is limited to the exact approved staging asset and approved low-impact methods. The assessor records time, tool version, target and outcome. If an excluded service appears in results, the assessor does not probe it and reports the boundary observation.

Practical design points

- Record the decision for 'integrated framework overview' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Test case	Expected framework response	Pass condition
Missing signature	Reject request	No testing permitted
Out-of-scope asset	Stop and escalate	No probing of excluded asset
Legal concern	Pause pending review	Written legal decision recorded
Delayed disclosure	Escalate to owner and sponsor	Updated timeline and status log

Process view

Walkthrough → Test cases → Record issue → Refine control → Repeat test → Accept

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 9 – INTEGRATE, TEST AND REFINE THE FRAMEWORK

Page 2 of 10 – End-to-end engagement walkthrough

Integration is tested through a fictional but realistic university assessment. The walkthrough begins with a department request and ends with a verified remediation and a closure record. No live exploitation is required or performed in this design exercise.

Testing includes positive cases and negative cases. The framework must reject missing authorization, block out-of-scope activity, pause when a legal conflict is identified and escalate when disclosure or remediation deadlines are missed.

Execution

The assessor checks the lab baseline first and validates test cases against an isolated target. Any production-facing check is limited to the exact approved staging asset and approved low-impact methods. The assessor records time, tool version, target and outcome. If an excluded service appears in results, the assessor does not probe it and reports the boundary observation.

Finding and remediation

A hypothetical configuration weakness is documented with a unique finding ID and minimum necessary evidence. The report is sent privately to the security lead and system owner. The owner assigns a remediation date. After the change, the assessor performs a permitted retest and records whether the issue is fixed, partially fixed or remains open.

Practical design points

- Record the decision for 'end-to-end engagement walkthrough' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Test case	Expected framework response	Pass condition
Missing signature	Reject request	No testing permitted
Out-of-scope asset	Stop and escalate	No probing of excluded asset
Legal concern	Pause pending review	Written legal decision recorded
Delayed disclosure	Escalate to owner and sponsor	Updated timeline and status log

Process view

Walkthrough → Test cases → Record issue → Refine control → Repeat test → Accept

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 9 – INTEGRATE, TEST AND REFINE THE FRAMEWORK

Page 3 of 10 – Request and authorization walkthrough

Integration is tested through a fictional but realistic university assessment. The walkthrough begins with a department request and ends with a verified remediation and a closure record. No live exploitation is required or performed in this design exercise.

Testing includes positive cases and negative cases. The framework must reject missing authorization, block out-of-scope activity, pause when a legal conflict is identified and escalate when disclosure or remediation deadlines are missed.

Finding and remediation

A hypothetical configuration weakness is documented with a unique finding ID and minimum necessary evidence. The report is sent privately to the security lead and system owner. The owner assigns a remediation date. After the change, the assessor performs a permitted retest and records whether the issue is fixed, partially fixed or remains open.

Closure

The coordinator confirms that all findings have owners, disclosure status is recorded, temporary accounts are disabled, evidence is stored according to retention rules and the system owner signs closure. The engagement is closed only after outstanding risks are accepted by an authorized decision-maker.

Practical design points

- Record the decision for 'request and authorization walkthrough' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Test case	Expected framework response	Pass condition
Missing signature	Reject request	No testing permitted
Out-of-scope asset	Stop and escalate	No probing of excluded asset
Legal concern	Pause pending review	Written legal decision recorded
Delayed disclosure	Escalate to owner and sponsor	Updated timeline and status log

Process view

Walkthrough → Test cases → Record issue → Refine control → Repeat test → Accept

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 9 – INTEGRATE, TEST AND REFINE THE FRAMEWORK

Page 4 of 10 – Scope and legal pre-check walkthrough

Integration is tested through a fictional but realistic university assessment. The walkthrough begins with a department request and ends with a verified remediation and a closure record. No live exploitation is required or performed in this design exercise.

Testing includes positive cases and negative cases. The framework must reject missing authorization, block out-of-scope activity, pause when a legal conflict is identified and escalate when disclosure or remediation deadlines are missed.

Closure

The coordinator confirms that all findings have owners, disclosure status is recorded, temporary accounts are disabled, evidence is stored according to retention rules and the system owner signs closure. The engagement is closed only after outstanding risks are accepted by an authorized decision-maker.

Walkthrough case

A department requests a security review of the student portal staging environment before an upgrade. The request is assigned an engagement ID. The owner confirms the staging hostname and test account. The security lead checks methods and schedule. Privacy staff confirm that synthetic records will be used. The sponsor signs the authorization and the RoE is attached.

Practical design points

- Record the decision for 'scope and legal pre-check walkthrough' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Test case	Expected framework response	Pass condition
Missing signature	Reject request	No testing permitted
Out-of-scope asset	Stop and escalate	No probing of excluded asset
Legal concern	Pause pending review	Written legal decision recorded
Delayed disclosure	Escalate to owner and sponsor	Updated timeline and status log

Process view

Walkthrough → Test cases → Record issue → Refine control → Repeat test → Accept

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 9 – INTEGRATE, TEST AND REFINE THE FRAMEWORK

Page 5 of 10 – Isolated-lab testing walkthrough

Integration is tested through a fictional but realistic university assessment. The walkthrough begins with a department request and ends with a verified remediation and a closure record. No live exploitation is required or performed in this design exercise.

Testing includes positive cases and negative cases. The framework must reject missing authorization, block out-of-scope activity, pause when a legal conflict is identified and escalate when disclosure or remediation deadlines are missed.

Walkthrough case

A department requests a security review of the student portal staging environment before an upgrade. The request is assigned an engagement ID. The owner confirms the staging hostname and test account. The security lead checks methods and schedule. Privacy staff confirm that synthetic records will be used. The sponsor signs the authorization and the RoE is attached.

Execution

The assessor checks the lab baseline first and validates test cases against an isolated target. Any production-facing check is limited to the exact approved staging asset and approved low-impact methods. The assessor records time, tool version, target and outcome. If an excluded service appears in results, the assessor does not probe it and reports the boundary observation.

Practical design points

- Record the decision for 'isolated-lab testing walkthrough' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Test case	Expected framework response	Pass condition
Missing signature	Reject request	No testing permitted
Out-of-scope asset	Stop and escalate	No probing of excluded asset
Legal concern	Pause pending review	Written legal decision recorded
Delayed disclosure	Escalate to owner and sponsor	Updated timeline and status log

Process view

Walkthrough → Test cases → Record issue → Refine control → Repeat test → Accept

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 9 – INTEGRATE, TEST AND REFINE THE FRAMEWORK

Page 6 of 10 – Finding triage and disclosure walkthrough

Integration is tested through a fictional but realistic university assessment. The walkthrough begins with a department request and ends with a verified remediation and a closure record. No live exploitation is required or performed in this design exercise.

Testing includes positive cases and negative cases. The framework must reject missing authorization, block out-of-scope activity, pause when a legal conflict is identified and escalate when disclosure or remediation deadlines are missed.

Execution

The assessor checks the lab baseline first and validates test cases against an isolated target. Any production-facing check is limited to the exact approved staging asset and approved low-impact methods. The assessor records time, tool version, target and outcome. If an excluded service appears in results, the assessor does not probe it and reports the boundary observation.

Finding and remediation

A hypothetical configuration weakness is documented with a unique finding ID and minimum necessary evidence. The report is sent privately to the security lead and system owner. The owner assigns a remediation date. After the change, the assessor performs a permitted retest and records whether the issue is fixed, partially fixed or remains open.

Practical design points

- Record the decision for 'finding triage and disclosure walkthrough' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Test case	Expected framework response	Pass condition
Missing signature	Reject request	No testing permitted
Out-of-scope asset	Stop and escalate	No probing of excluded asset
Legal concern	Pause pending review	Written legal decision recorded
Delayed disclosure	Escalate to owner and sponsor	Updated timeline and status log

Process view

Walkthrough → Test cases → Record issue → Refine control → Repeat test → Accept

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 9 – INTEGRATE, TEST AND REFINE THE FRAMEWORK

Page 7 of 10 – Systematic negative test cases

Integration is tested through a fictional but realistic university assessment. The walkthrough begins with a department request and ends with a verified remediation and a closure record. No live exploitation is required or performed in this design exercise.

Testing includes positive cases and negative cases. The framework must reject missing authorization, block out-of-scope activity, pause when a legal conflict is identified and escalate when disclosure or remediation deadlines are missed.

Finding and remediation

A hypothetical configuration weakness is documented with a unique finding ID and minimum necessary evidence. The report is sent privately to the security lead and system owner. The owner assigns a remediation date. After the change, the assessor performs a permitted retest and records whether the issue is fixed, partially fixed or remains open.

Closure

The coordinator confirms that all findings have owners, disclosure status is recorded, temporary accounts are disabled, evidence is stored according to retention rules and the system owner signs closure. The engagement is closed only after outstanding risks are accepted by an authorized decision-maker.

Practical design points

- Record the decision for 'systematic negative test cases' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Test case	Expected framework response	Pass condition
Missing signature	Reject request	No testing permitted
Out-of-scope asset	Stop and escalate	No probing of excluded asset
Legal concern	Pause pending review	Written legal decision recorded
Delayed disclosure	Escalate to owner and sponsor	Updated timeline and status log

Process view

Walkthrough → Test cases → Record issue → Refine control → Repeat test → Accept

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 9 – INTEGRATE, TEST AND REFINE THE FRAMEWORK

Page 8 of 10 – Walkthrough issues and root-cause analysis

Integration is tested through a fictional but realistic university assessment. The walkthrough begins with a department request and ends with a verified remediation and a closure record. No live exploitation is required or performed in this design exercise.

Testing includes positive cases and negative cases. The framework must reject missing authorization, block out-of-scope activity, pause when a legal conflict is identified and escalate when disclosure or remediation deadlines are missed.

Closure

The coordinator confirms that all findings have owners, disclosure status is recorded, temporary accounts are disabled, evidence is stored according to retention rules and the system owner signs closure. The engagement is closed only after outstanding risks are accepted by an authorized decision-maker.

Walkthrough case

A department requests a security review of the student portal staging environment before an upgrade. The request is assigned an engagement ID. The owner confirms the staging hostname and test account. The security lead checks methods and schedule. Privacy staff confirm that synthetic records will be used. The sponsor signs the authorization and the RoE is attached.

Practical design points

- Record the decision for 'walkthrough issues and root-cause analysis' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Test case	Expected framework response	Pass condition
Missing signature	Reject request	No testing permitted
Out-of-scope asset	Stop and escalate	No probing of excluded asset
Legal concern	Pause pending review	Written legal decision recorded
Delayed disclosure	Escalate to owner and sponsor	Updated timeline and status log

Process view

Walkthrough → Test cases → Record issue → Refine control → Repeat test → Accept

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 9 – INTEGRATE, TEST AND REFINE THE FRAMEWORK

Page 9 of 10 – Refinement actions and retest results

Integration is tested through a fictional but realistic university assessment. The walkthrough begins with a department request and ends with a verified remediation and a closure record. No live exploitation is required or performed in this design exercise.

Testing includes positive cases and negative cases. The framework must reject missing authorization, block out-of-scope activity, pause when a legal conflict is identified and escalate when disclosure or remediation deadlines are missed.

Walkthrough case

A department requests a security review of the student portal staging environment before an upgrade. The request is assigned an engagement ID. The owner confirms the staging hostname and test account. The security lead checks methods and schedule. Privacy staff confirm that synthetic records will be used. The sponsor signs the authorization and the RoE is attached.

Execution

The assessor checks the lab baseline first and validates test cases against an isolated target. Any production-facing check is limited to the exact approved staging asset and approved low-impact methods. The assessor records time, tool version, target and outcome. If an excluded service appears in results, the assessor does not probe it and reports the boundary observation.

Practical design points

- Record the decision for 'refinement actions and retest results' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Test case	Expected framework response	Pass condition
Missing signature	Reject request	No testing permitted
Out-of-scope asset	Stop and escalate	No probing of excluded asset
Legal concern	Pause pending review	Written legal decision recorded
Delayed disclosure	Escalate to owner and sponsor	Updated timeline and status log

Process view

Walkthrough → Test cases → Record issue → Refine control → Repeat test → Accept

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 9 – INTEGRATE, TEST AND REFINE THE FRAMEWORK

Page 10 of 10 – Final integrated framework acceptance

Integration is tested through a fictional but realistic university assessment. The walkthrough begins with a department request and ends with a verified remediation and a closure record. No live exploitation is required or performed in this design exercise.

Testing includes positive cases and negative cases. The framework must reject missing authorization, block out-of-scope activity, pause when a legal conflict is identified and escalate when disclosure or remediation deadlines are missed.

Execution

The assessor checks the lab baseline first and validates test cases against an isolated target. Any production-facing check is limited to the exact approved staging asset and approved low-impact methods. The assessor records time, tool version, target and outcome. If an excluded service appears in results, the assessor does not probe it and reports the boundary observation.

Finding and remediation

A hypothetical configuration weakness is documented with a unique finding ID and minimum necessary evidence. The report is sent privately to the security lead and system owner. The owner assigns a remediation date. After the change, the assessor performs a permitted retest and records whether the issue is fixed, partially fixed or remains open.

Practical design points

- Record the decision for 'final integrated framework acceptance' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Test case	Expected framework response	Pass condition
Missing signature	Reject request	No testing permitted
Out-of-scope asset	Stop and escalate	No probing of excluded asset
Legal concern	Pause pending review	Written legal decision recorded
Delayed disclosure	Escalate to owner and sponsor	Updated timeline and status log

Process view

Walkthrough → Test cases → Record issue → Refine control → Repeat test → Accept

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 10 – CREATE A SCALABILITY AND GOVERNANCE EVALUATION

Page 1 of 10 – Evaluation purpose, assumptions and method

The evaluation compares a small programme run by one department with a larger programme covering the university and external assessors. Measurements in this assignment are illustrative planning estimates, not empirical results from a real university deployment.

The purpose of measurement is to identify governance bottlenecks. Approval turnaround, scope coverage, onboarding steps and overdue findings are useful because they reveal whether controls remain practical as the number of assets and assessors grows.

Measurement design

The comparison uses illustrative estimates to test the design, not measured performance from a real university. Small programme: one department, five systems and two assessors. Large programme: 20 initial systems expanding to 100 systems, 50 staff and a pool of ten internal or external assessors. The estimates help identify process steps that may become bottlenecks.

Processes

Three processes are measured: approval turnaround, scope coverage and external assessor onboarding. Approval turnaround is measured from a complete request to signed authorization. Scope coverage is the proportion of requested assets with an owner, identifier and decision. Onboarding steps count required checks before a third-party assessor can begin.

Practical design points

- Record the decision for 'evaluation purpose, assumptions and method' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Measure	Small programme (illustrative)	Large programme (illustrative)
Systems	5	100
Assessors	2	10 internal / external pool
Approval turnaround	2 working days	5 working days
Scope coverage at intake	100% after owner review	95% initial; remainder escalated
Onboarding steps	4	7

Process view

Define scale → Measure processes → Compare results → Find bottleneck → Refine governance

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 10 – CREATE A SCALABILITY AND GOVERNANCE EVALUATION

Page 2 of 10 – Small-programme scenario

The evaluation compares a small programme run by one department with a larger programme covering the university and external assessors. Measurements in this assignment are illustrative planning estimates, not empirical results from a real university deployment.

The purpose of measurement is to identify governance bottlenecks. Approval turnaround, scope coverage, onboarding steps and overdue findings are useful because they reveal whether controls remain practical as the number of assets and assessors grows.

Processes

Three processes are measured: approval turnaround, scope coverage and external assessor onboarding. Approval turnaround is measured from a complete request to signed authorization. Scope coverage is the proportion of requested assets with an owner, identifier and decision. Onboarding steps count required checks before a third-party assessor can begin.

Interpretation

A small programme can rely on a coordinator and a shared register. A larger programme needs delegated approval limits, standard templates, automated expiry reminders and periodic supplier reviews. Automation should not bypass authorization. High-risk assets and personal-data processing still require human review.

Practical design points

- Record the decision for 'small-programme scenario' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Measure	Small programme (illustrative)	Large programme (illustrative)
Systems	5	100
Assessors	2	10 internal / external pool
Approval turnaround	2 working days	5 working days
Scope coverage at intake	100% after owner review	95% initial; remainder escalated
Onboarding steps	4	7

Process view

Define scale → Measure processes → Compare results → Find bottleneck → Refine governance

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 10 – CREATE A SCALABILITY AND GOVERNANCE EVALUATION

Page 3 of 10 – University-wide programme scenario

The evaluation compares a small programme run by one department with a larger programme covering the university and external assessors. Measurements in this assignment are illustrative planning estimates, not empirical results from a real university deployment.

The purpose of measurement is to identify governance bottlenecks. Approval turnaround, scope coverage, onboarding steps and overdue findings are useful because they reveal whether controls remain practical as the number of assets and assessors grows.

Interpretation

A small programme can rely on a coordinator and a shared register. A larger programme needs delegated approval limits, standard templates, automated expiry reminders and periodic supplier reviews. Automation should not bypass authorization. High-risk assets and personal-data processing still require human review.

Governance refinement

The evaluation supports a tiered review model. Low-risk lab-only work may use a shorter approval route, while production, personal-data or third-party assessments require privacy and legal review. The programme should track overdue approvals, unowned assets and findings past their remediation date.

Practical design points

- Record the decision for 'university-wide programme scenario' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Measure	Small programme (illustrative)	Large programme (illustrative)
Systems	5	100
Assessors	2	10 internal / external pool
Approval turnaround	2 working days	5 working days
Scope coverage at intake	100% after owner review	95% initial; remainder escalated
Onboarding steps	4	7

Process view

Define scale → Measure processes → Compare results → Find bottleneck → Refine governance

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 10 – CREATE A SCALABILITY AND GOVERNANCE EVALUATION

Page 4 of 10 – Approval turnaround measurement

The evaluation compares a small programme run by one department with a larger programme covering the university and external assessors. Measurements in this assignment are illustrative planning estimates, not empirical results from a real university deployment.

The purpose of measurement is to identify governance bottlenecks. Approval turnaround, scope coverage, onboarding steps and overdue findings are useful because they reveal whether controls remain practical as the number of assets and assessors grows.

Governance refinement

The evaluation supports a tiered review model. Low-risk lab-only work may use a shorter approval route, while production, personal-data or third-party assessments require privacy and legal review. The programme should track overdue approvals, unowned assets and findings past their remediation date.

Measurement design

The comparison uses illustrative estimates to test the design, not measured performance from a real university. Small programme: one department, five systems and two assessors. Large programme: 20 initial systems expanding to 100 systems, 50 staff and a pool of ten internal or external assessors. The estimates help identify process steps that may become bottlenecks.

Practical design points

- Record the decision for 'approval turnaround measurement' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Measure	Small programme (illustrative)	Large programme (illustrative)
Systems	5	100
Assessors	2	10 internal / external pool
Approval turnaround	2 working days	5 working days
Scope coverage at intake	100% after owner review	95% initial; remainder escalated
Onboarding steps	4	7

Process view

Define scale → Measure processes → Compare results → Find bottleneck → Refine governance

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 10 – CREATE A SCALABILITY AND GOVERNANCE EVALUATION

Page 5 of 10 – Scope coverage and workflow-step measurement

The evaluation compares a small programme run by one department with a larger programme covering the university and external assessors. Measurements in this assignment are illustrative planning estimates, not empirical results from a real university deployment.

The purpose of measurement is to identify governance bottlenecks. Approval turnaround, scope coverage, onboarding steps and overdue findings are useful because they reveal whether controls remain practical as the number of assets and assessors grows.

Measurement design

The comparison uses illustrative estimates to test the design, not measured performance from a real university. Small programme: one department, five systems and two assessors. Large programme: 20 initial systems expanding to 100 systems, 50 staff and a pool of ten internal or external assessors. The estimates help identify process steps that may become bottlenecks.

Processes

Three processes are measured: approval turnaround, scope coverage and external assessor onboarding. Approval turnaround is measured from a complete request to signed authorization. Scope coverage is the proportion of requested assets with an owner, identifier and decision. Onboarding steps count required checks before a third-party assessor can begin.

Practical design points

- Record the decision for 'scope coverage and workflow-step measurement' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Measure	Small programme (illustrative)	Large programme (illustrative)
Systems	5	100
Assessors	2	10 internal / external pool
Approval turnaround	2 working days	5 working days
Scope coverage at intake	100% after owner review	95% initial; remainder escalated
Onboarding steps	4	7

Process view

Define scale → Measure processes → Compare results → Find bottleneck → Refine governance

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 10 – CREATE A SCALABILITY AND GOVERNANCE EVALUATION

Page 6 of 10 – External assessor onboarding evaluation

The evaluation compares a small programme run by one department with a larger programme covering the university and external assessors. Measurements in this assignment are illustrative planning estimates, not empirical results from a real university deployment.

The purpose of measurement is to identify governance bottlenecks. Approval turnaround, scope coverage, onboarding steps and overdue findings are useful because they reveal whether controls remain practical as the number of assets and assessors grows.

Processes

Three processes are measured: approval turnaround, scope coverage and external assessor onboarding. Approval turnaround is measured from a complete request to signed authorization. Scope coverage is the proportion of requested assets with an owner, identifier and decision. Onboarding steps count required checks before a third-party assessor can begin.

Interpretation

A small programme can rely on a coordinator and a shared register. A larger programme needs delegated approval limits, standard templates, automated expiry reminders and periodic supplier reviews. Automation should not bypass authorization. High-risk assets and personal-data processing still require human review.

Practical design points

- Record the decision for 'external assessor onboarding evaluation' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Measure	Small programme (illustrative)	Large programme (illustrative)
Systems	5	100
Assessors	2	10 internal / external pool
Approval turnaround	2 working days	5 working days
Scope coverage at intake	100% after owner review	95% initial; remainder escalated
Onboarding steps	4	7

Process view

Define scale → Measure processes → Compare results → Find bottleneck → Refine governance

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 10 – CREATE A SCALABILITY AND GOVERNANCE EVALUATION

Page 7 of 10 – Comparison table and interpretation

The evaluation compares a small programme run by one department with a larger programme covering the university and external assessors. Measurements in this assignment are illustrative planning estimates, not empirical results from a real university deployment.

The purpose of measurement is to identify governance bottlenecks. Approval turnaround, scope coverage, onboarding steps and overdue findings are useful because they reveal whether controls remain practical as the number of assets and assessors grows.

Interpretation

A small programme can rely on a coordinator and a shared register. A larger programme needs delegated approval limits, standard templates, automated expiry reminders and periodic supplier reviews. Automation should not bypass authorization. High-risk assets and personal-data processing still require human review.

Governance refinement

The evaluation supports a tiered review model. Low-risk lab-only work may use a shorter approval route, while production, personal-data or third-party assessments require privacy and legal review. The programme should track overdue approvals, unowned assets and findings past their remediation date.

Practical design points

- Record the decision for 'comparison table and interpretation' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Measure	Small programme (illustrative)	Large programme (illustrative)
Systems	5	100
Assessors	2	10 internal / external pool
Approval turnaround	2 working days	5 working days
Scope coverage at intake	100% after owner review	95% initial; remainder escalated
Onboarding steps	4	7

Process view

Define scale → Measure processes → Compare results → Find bottleneck → Refine governance

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 10 – CREATE A SCALABILITY AND GOVERNANCE EVALUATION

Page 8 of 10 – Visualisation of illustrative measures

The evaluation compares a small programme run by one department with a larger programme covering the university and external assessors. Measurements in this assignment are illustrative planning estimates, not empirical results from a real university deployment.

The purpose of measurement is to identify governance bottlenecks. Approval turnaround, scope coverage, onboarding steps and overdue findings are useful because they reveal whether controls remain practical as the number of assets and assessors grows.

Governance refinement

The evaluation supports a tiered review model. Low-risk lab-only work may use a shorter approval route, while production, personal-data or third-party assessments require privacy and legal review. The programme should track overdue approvals, unowned assets and findings past their remediation date.

Measurement design

The comparison uses illustrative estimates to test the design, not measured performance from a real university. Small programme: one department, five systems and two assessors. Large programme: 20 initial systems expanding to 100 systems, 50 staff and a pool of ten internal or external assessors. The estimates help identify process steps that may become bottlenecks.

Practical design points

- Record the decision for 'visualisation of illustrative measures' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Measure	Small programme (illustrative)	Large programme (illustrative)
Systems	5	100
Assessors	2	10 internal / external pool
Approval turnaround	2 working days	5 working days
Scope coverage at intake	100% after owner review	95% initial; remainder escalated
Onboarding steps	4	7

Process view

Define scale → Measure processes → Compare results → Find bottleneck → Refine governance

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 10 – CREATE A SCALABILITY AND GOVERNANCE EVALUATION

Page 9 of 10 – Governance refinements based on evidence

The evaluation compares a small programme run by one department with a larger programme covering the university and external assessors. Measurements in this assignment are illustrative planning estimates, not empirical results from a real university deployment.

The purpose of measurement is to identify governance bottlenecks. Approval turnaround, scope coverage, onboarding steps and overdue findings are useful because they reveal whether controls remain practical as the number of assets and assessors grows.

Measurement design

The comparison uses illustrative estimates to test the design, not measured performance from a real university. Small programme: one department, five systems and two assessors. Large programme: 20 initial systems expanding to 100 systems, 50 staff and a pool of ten internal or external assessors. The estimates help identify process steps that may become bottlenecks.

Processes

Three processes are measured: approval turnaround, scope coverage and external assessor onboarding. Approval turnaround is measured from a complete request to signed authorization. Scope coverage is the proportion of requested assets with an owner, identifier and decision. Onboarding steps count required checks before a third-party assessor can begin.

Practical design points

- Record the decision for 'governance refinements based on evidence' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Measure	Small programme (illustrative)	Large programme (illustrative)
Systems	5	100
Assessors	2	10 internal / external pool
Approval turnaround	2 working days	5 working days
Scope coverage at intake	100% after owner review	95% initial; remainder escalated
Onboarding steps	4	7

Process view

Define scale → Measure processes → Compare results → Find bottleneck → Refine governance

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 10 – CREATE A SCALABILITY AND GOVERNANCE EVALUATION

Page 10 of 10 – Scalability evaluation conclusion

The evaluation compares a small programme run by one department with a larger programme covering the university and external assessors. Measurements in this assignment are illustrative planning estimates, not empirical results from a real university deployment.

The purpose of measurement is to identify governance bottlenecks. Approval turnaround, scope coverage, onboarding steps and overdue findings are useful because they reveal whether controls remain practical as the number of assets and assessors grows.

Processes

Three processes are measured: approval turnaround, scope coverage and external assessor onboarding. Approval turnaround is measured from a complete request to signed authorization. Scope coverage is the proportion of requested assets with an owner, identifier and decision. Onboarding steps count required checks before a third-party assessor can begin.

Interpretation

A small programme can rely on a coordinator and a shared register. A larger programme needs delegated approval limits, standard templates, automated expiry reminders and periodic supplier reviews. Automation should not bypass authorization. High-risk assets and personal-data processing still require human review.

Practical design points

- Record the decision for 'scalability evaluation conclusion' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Measure	Small programme (illustrative)	Large programme (illustrative)
Systems	5	100
Assessors	2	10 internal / external pool
Approval turnaround	2 working days	5 working days
Scope coverage at intake	100% after owner review	95% initial; remainder escalated
Onboarding steps	4	7

Process view

Define scale → Measure processes → Compare results → Find bottleneck → Refine governance

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT

Page 1 of 10 – Changed requirement and impact analysis

The changed requirement introduces continuous assessments, third-party testers, stricter data-protection expectations and a shorter disclosure timeline. The original framework is retained where its controls remain effective and revised where continuous operation creates new risks.

The revised design uses recurring authorization windows, supplier assurance, data minimisation, rapid triage and an auditable continuous-assurance register. Automation may support reminders and evidence collection, but a responsible person remains accountable for approvals and disclosure decisions.

Requirement impact

Continuous assessments make one-time approval insufficient unless the authorization clearly defines recurring windows, frequency, methods, assets and expiry. Third-party assessors introduce supplier due diligence, confidentiality commitments, personnel changes and subcontractor risk. Stricter data protection requires stronger minimisation, access controls, retention and incident escalation.

Component decisions

Retain the core authorization, scope, RoE, ethics, legal mapping, isolated lab, document library and coordinated disclosure model. Modify authorization to include recurring windows and periodic revalidation. Modify RoE to identify third-party access and data handling. Add supplier assurance and continuous monitoring of expiry and scope changes.

Practical design points

- Record the decision for 'changed requirement and impact analysis' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Decision	Reason
Authorization	Modify	Recurring windows and renewal are needed
RoE	Modify	Include third-party and continuous testing boundaries
Lab	Retain and extend	Continue isolated validation
Disclosure	Modify	Shorter triage and remediation checkpoints
Document library	Retain and version	Reusable templates support scale

Process view

Changed requirement → Gap review → Modify components → Integrate register → Validate → Defend

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT

Page 2 of 10 – Retain, modify, replace and redesign decisions

The changed requirement introduces continuous assessments, third-party testers, stricter data-protection expectations and a shorter disclosure timeline. The original framework is retained where its controls remain effective and revised where continuous operation creates new risks.

The revised design uses recurring authorization windows, supplier assurance, data minimisation, rapid triage and an auditable continuous-assurance register. Automation may support reminders and evidence collection, but a responsible person remains accountable for approvals and disclosure decisions.

Component decisions

Retain the core authorization, scope, RoE, ethics, legal mapping, isolated lab, document library and coordinated disclosure model. Modify authorization to include recurring windows and periodic revalidation. Modify RoE to identify third-party access and data handling. Add supplier assurance and continuous monitoring of expiry and scope changes.

Continuous assurance register

The new register stores engagement ID, asset ID, authorization period, approved assessor, supplier, test frequency, data category, last review, next review, current status, open findings and disclosure deadline. Alerts identify expired permissions, unreviewed scope changes and overdue remediation. A human owner must approve renewal or suspension.

Practical design points

- Record the decision for 'retain, modify, replace and redesign decisions' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Decision	Reason
Authorization	Modify	Recurring windows and renewal are needed
RoE	Modify	Include third-party and continuous testing boundaries
Lab	Retain and extend	Continue isolated validation
Disclosure	Modify	Shorter triage and remediation checkpoints
Document library	Retain and version	Reusable templates support scale

Process view

Changed requirement → Gap review → Modify components → Integrate register → Validate → Defend

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT

Page 3 of 10 – Continuous assessment governance

The changed requirement introduces continuous assessments, third-party testers, stricter data-protection expectations and a shorter disclosure timeline. The original framework is retained where its controls remain effective and revised where continuous operation creates new risks.

The revised design uses recurring authorization windows, supplier assurance, data minimisation, rapid triage and an auditable continuous-assurance register. Automation may support reminders and evidence collection, but a responsible person remains accountable for approvals and disclosure decisions.

Continuous assurance register

The new register stores engagement ID, asset ID, authorization period, approved assessor, supplier, test frequency, data category, last review, next review, current status, open findings and disclosure deadline. Alerts identify expired permissions, unreviewed scope changes and overdue remediation. A human owner must approve renewal or suspension.

Final defence

The revised framework remains practical because it reuses the original controls and adds a small number of targeted controls for continuous and third-party work. It reduces repeated paperwork through reusable records while preserving human approval for high-risk decisions. Remaining trade-offs include administrative overhead and the risk that automation creates false confidence.

Practical design points

- Record the decision for 'continuous assessment governance' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Decision	Reason
Authorization	Modify	Recurring windows and renewal are needed
RoE	Modify	Include third-party and continuous testing boundaries
Lab	Retain and extend	Continue isolated validation
Disclosure	Modify	Shorter triage and remediation checkpoints
Document library	Retain and version	Reusable templates support scale

Process view

Changed requirement → Gap review → Modify components → Integrate register → Validate → Defend

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT

Page 4 of 10 – Third-party assessor controls

The changed requirement introduces continuous assessments, third-party testers, stricter data-protection expectations and a shorter disclosure timeline. The original framework is retained where its controls remain effective and revised where continuous operation creates new risks.

The revised design uses recurring authorization windows, supplier assurance, data minimisation, rapid triage and an auditable continuous-assurance register. Automation may support reminders and evidence collection, but a responsible person remains accountable for approvals and disclosure decisions.

Final defence

The revised framework remains practical because it reuses the original controls and adds a small number of targeted controls for continuous and third-party work. It reduces repeated paperwork through reusable records while preserving human approval for high-risk decisions. Remaining trade-offs include administrative overhead and the risk that automation creates false confidence.

Requirement impact

Continuous assessments make one-time approval insufficient unless the authorization clearly defines recurring windows, frequency, methods, assets and expiry. Third-party assessors introduce supplier due diligence, confidentiality commitments, personnel changes and subcontractor risk. Stricter data protection requires stronger minimisation, access controls, retention and incident escalation.

Practical design points

- Record the decision for 'third-party assessor controls' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Decision	Reason
Authorization	Modify	Recurring windows and renewal are needed
RoE	Modify	Include third-party and continuous testing boundaries
Lab	Retain and extend	Continue isolated validation
Disclosure	Modify	Shorter triage and remediation checkpoints
Document library	Retain and version	Reusable templates support scale

Process view

Changed requirement → Gap review → Modify components → Integrate register → Validate → Defend

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT

Page 5 of 10 – Stricter personal-data protection

The changed requirement introduces continuous assessments, third-party testers, stricter data-protection expectations and a shorter disclosure timeline. The original framework is retained where its controls remain effective and revised where continuous operation creates new risks.

The revised design uses recurring authorization windows, supplier assurance, data minimisation, rapid triage and an auditable continuous-assurance register. Automation may support reminders and evidence collection, but a responsible person remains accountable for approvals and disclosure decisions.

Requirement impact

Continuous assessments make one-time approval insufficient unless the authorization clearly defines recurring windows, frequency, methods, assets and expiry. Third-party assessors introduce supplier due diligence, confidentiality commitments, personnel changes and subcontractor risk. Stricter data protection requires stronger minimisation, access controls, retention and incident escalation.

Component decisions

Retain the core authorization, scope, RoE, ethics, legal mapping, isolated lab, document library and coordinated disclosure model. Modify authorization to include recurring windows and periodic revalidation. Modify RoE to identify third-party access and data handling. Add supplier assurance and continuous monitoring of expiry and scope changes.

Practical design points

- Record the decision for 'stricter personal-data protection' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Decision	Reason
Authorization	Modify	Recurring windows and renewal are needed
RoE	Modify	Include third-party and continuous testing boundaries
Lab	Retain and extend	Continue isolated validation
Disclosure	Modify	Shorter triage and remediation checkpoints
Document library	Retain and version	Reusable templates support scale

Process view

Changed requirement → Gap review → Modify components → Integrate register → Validate → Defend

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT

Page 6 of 10 – Shorter coordinated-disclosure timeline

The changed requirement introduces continuous assessments, third-party testers, stricter data-protection expectations and a shorter disclosure timeline. The original framework is retained where its controls remain effective and revised where continuous operation creates new risks.

The revised design uses recurring authorization windows, supplier assurance, data minimisation, rapid triage and an auditable continuous-assurance register. Automation may support reminders and evidence collection, but a responsible person remains accountable for approvals and disclosure decisions.

Component decisions

Retain the core authorization, scope, RoE, ethics, legal mapping, isolated lab, document library and coordinated disclosure model. Modify authorization to include recurring windows and periodic revalidation. Modify RoE to identify third-party access and data handling. Add supplier assurance and continuous monitoring of expiry and scope changes.

Continuous assurance register

The new register stores engagement ID, asset ID, authorization period, approved assessor, supplier, test frequency, data category, last review, next review, current status, open findings and disclosure deadline. Alerts identify expired permissions, unreviewed scope changes and overdue remediation. A human owner must approve renewal or suspension.

Practical design points

- Record the decision for 'shorter coordinated-disclosure timeline' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Decision	Reason
Authorization	Modify	Recurring windows and renewal are needed
RoE	Modify	Include third-party and continuous testing boundaries
Lab	Retain and extend	Continue isolated validation
Disclosure	Modify	Shorter triage and remediation checkpoints
Document library	Retain and version	Reusable templates support scale

Process view

Changed requirement → Gap review → Modify components → Integrate register → Validate → Defend

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT

Page 7 of 10 – New component: continuous assurance register

The changed requirement introduces continuous assessments, third-party testers, stricter data-protection expectations and a shorter disclosure timeline. The original framework is retained where its controls remain effective and revised where continuous operation creates new risks.

The revised design uses recurring authorization windows, supplier assurance, data minimisation, rapid triage and an auditable continuous-assurance register. Automation may support reminders and evidence collection, but a responsible person remains accountable for approvals and disclosure decisions.

Continuous assurance register

The new register stores engagement ID, asset ID, authorization period, approved assessor, supplier, test frequency, data category, last review, next review, current status, open findings and disclosure deadline. Alerts identify expired permissions, unreviewed scope changes and overdue remediation. A human owner must approve renewal or suspension.

Final defence

The revised framework remains practical because it reuses the original controls and adds a small number of targeted controls for continuous and third-party work. It reduces repeated paperwork through reusable records while preserving human approval for high-risk decisions. Remaining trade-offs include administrative overhead and the risk that automation creates false confidence.

Practical design points

- Record the decision for 'new component: continuous assurance register' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Decision	Reason
Authorization	Modify	Recurring windows and renewal are needed
RoE	Modify	Include third-party and continuous testing boundaries
Lab	Retain and extend	Continue isolated validation
Disclosure	Modify	Shorter triage and remediation checkpoints
Document library	Retain and version	Reusable templates support scale

Process view

Changed requirement → Gap review → Modify components → Integrate register → Validate → Defend

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT

Page 8 of 10 – Integration with existing framework

The changed requirement introduces continuous assessments, third-party testers, stricter data-protection expectations and a shorter disclosure timeline. The original framework is retained where its controls remain effective and revised where continuous operation creates new risks.

The revised design uses recurring authorization windows, supplier assurance, data minimisation, rapid triage and an auditable continuous-assurance register. Automation may support reminders and evidence collection, but a responsible person remains accountable for approvals and disclosure decisions.

Final defence

The revised framework remains practical because it reuses the original controls and adds a small number of targeted controls for continuous and third-party work. It reduces repeated paperwork through reusable records while preserving human approval for high-risk decisions. Remaining trade-offs include administrative overhead and the risk that automation creates false confidence.

Requirement impact

Continuous assessments make one-time approval insufficient unless the authorization clearly defines recurring windows, frequency, methods, assets and expiry. Third-party assessors introduce supplier due diligence, confidentiality commitments, personnel changes and subcontractor risk. Stricter data protection requires stronger minimisation, access controls, retention and incident escalation.

Practical design points

- Record the decision for 'integration with existing framework' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Decision	Reason
Authorization	Modify	Recurring windows and renewal are needed
RoE	Modify	Include third-party and continuous testing boundaries
Lab	Retain and extend	Continue isolated validation
Disclosure	Modify	Shorter triage and remediation checkpoints
Document library	Retain and version	Reusable templates support scale

Process view

Changed requirement → Gap review → Modify components → Integrate register → Validate → Defend

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT

Page 9 of 10 – Evidence-based defence and remaining trade-offs

The changed requirement introduces continuous assessments, third-party testers, stricter data-protection expectations and a shorter disclosure timeline. The original framework is retained where its controls remain effective and revised where continuous operation creates new risks.

The revised design uses recurring authorization windows, supplier assurance, data minimisation, rapid triage and an auditable continuous-assurance register. Automation may support reminders and evidence collection, but a responsible person remains accountable for approvals and disclosure decisions.

Requirement impact

Continuous assessments make one-time approval insufficient unless the authorization clearly defines recurring windows, frequency, methods, assets and expiry. Third-party assessors introduce supplier due diligence, confidentiality commitments, personnel changes and subcontractor risk. Stricter data protection requires stronger minimisation, access controls, retention and incident escalation.

Component decisions

Retain the core authorization, scope, RoE, ethics, legal mapping, isolated lab, document library and coordinated disclosure model. Modify authorization to include recurring windows and periodic revalidation. Modify RoE to identify third-party access and data handling. Add supplier assurance and continuous monitoring of expiry and scope changes.

Practical design points

- Record the decision for 'evidence-based defence and remaining trade-offs' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Decision	Reason
Authorization	Modify	Recurring windows and renewal are needed
RoE	Modify	Include third-party and continuous testing boundaries
Lab	Retain and extend	Continue isolated validation
Disclosure	Modify	Shorter triage and remediation checkpoints
Document library	Retain and version	Reusable templates support scale

Process view

Changed requirement → Gap review → Modify components → Integrate register → Validate → Defend

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT

Page 10 of 10 – Future improvements and final defence

The changed requirement introduces continuous assessments, third-party testers, stricter data-protection expectations and a shorter disclosure timeline. The original framework is retained where its controls remain effective and revised where continuous operation creates new risks.

The revised design uses recurring authorization windows, supplier assurance, data minimisation, rapid triage and an auditable continuous-assurance register. Automation may support reminders and evidence collection, but a responsible person remains accountable for approvals and disclosure decisions.

Component decisions

Retain the core authorization, scope, RoE, ethics, legal mapping, isolated lab, document library and coordinated disclosure model. Modify authorization to include recurring windows and periodic revalidation. Modify RoE to identify third-party access and data handling. Add supplier assurance and continuous monitoring of expiry and scope changes.

Continuous assurance register

The new register stores engagement ID, asset ID, authorization period, approved assessor, supplier, test frequency, data category, last review, next review, current status, open findings and disclosure deadline. Alerts identify expired permissions, unreviewed scope changes and overdue remediation. A human owner must approve renewal or suspension.

Practical design points

- Record the decision for 'future improvements and final defence' against the engagement ID and identify the person responsible for approval.
- Keep the asset boundary, evidence source and review date visible so that another team member can repeat the decision.
- If information is missing or a risk exceeds the approved limit, pause the activity and request a documented decision.

Component	Decision	Reason
Authorization	Modify	Recurring windows and renewal are needed
RoE	Modify	Include third-party and continuous testing boundaries
Lab	Retain and extend	Continue isolated validation
Disclosure	Modify	Shorter triage and remediation checkpoints
Document library	Retain and version	Reusable templates support scale

Process view

Changed requirement → Gap review → Modify components → Integrate register → Validate → Defend

Page record: This section is a design proposal for the assignment scenario. Any operational assessment would require current institutional approval, confirmation of asset ownership, and review of the applicable law and supplier terms before testing begins.

Selected references and source notes

Sources: Student-supplied Ethical Hacking Assignment 1 brief; Government of India, Information Technology Act, 2000 (India Code); Digital Personal Data Protection Act, 2023 and DPDP Rules, 2025 (MeitY); United States Code, Title 18, Section 1030 (CFAA). Legal provisions and commencement dates must be checked in the official current text before a real engagement. This academic design is not legal advice. Official portals: indiacode.nic.in, meity.gov.in and uscode.house.gov.